



Universidad
Europea

SISTEMA DE GESTIÓN DE LA SEGURIDAD DE LA INFORMACIÓN



ATHENEA S.A.

Código del documento:	CONF-SGSI-ATHENEA
Versión:	1.2
Fecha de aprobación:	04 de mayo de 2026
Clasificación:	CONFIDENCIAL – USO INTERNO
Propietario:	ATHENEA, S. A.
Ámbito de aplicación:	Todos los centros, sistemas y personal de ATHENEA, S. A.
Próxima revisión:	Mayo de 2027

HISTORIAL DE REVISIONES

VERSIÓN	FECHA	ELABORADO POR	APROBADO POR	DESCRIPCIÓN
1.0	14/04/2026	Comité de Seguridad	Ian Santillán (CEO)	Versión inicial del SGSI conforme a categoría media.
1.1	20/04/2026	Comité de Seguridad	Ian Santillán (CEO)	Corrección de formato, DdA y controles menores.
1.2	04/05/2026	Comité de Seguridad	Ian Santillán (CEO)	Versión final, corregida.

ÍNDICE

1. OBJETO Y ALCANCE	1
1.1. OBJETO	1
1.2. ALCANCE	1
1.3. CATEGORÍA ENS	1
1.4. PRINCIPIOS BÁSICOS ENS APLICADOS	2
2. MARCO NORMATIVO	2
2.1. LEGISLACIÓN APLICABLE	3
2.2. NORMAS Y ESTÁNDARES TÉCNICOS DE REFERENCIA	3
3. POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN	3
3.1. DECLARACIÓN DE INTENCIONES	3
3.2. PRINCIPIOS RECTORES	3
3.3. OBJETIVOS DE SEGURIDAD	4
3.4. INCUMPLIMIENTO	4
4. ORGANIZACIÓN DE LA SEGURIDAD	4
4.1. CONSEJO DE ADMINISTRACIÓN	4
4.2. COMITÉ DE SEGURIDAD DE LA INFORMACIÓN (CSI)	5
4.2.1. <i>Presidente del Comité de Seguridad - Ian Isaac Santillán Cueva (CEO)</i>	5
4.2.2. <i>Responsable de Servicio - Francisco de Borja Rodríguez Reig (CIO)</i>	5
4.2.3. <i>Responsable de Seguridad - Miguel Zamora Jiménez (CISO)</i>	5
4.2.4. <i>Responsable de Información - Aitor Jiang (CDO)</i>	6
4.2.5. <i>Responsable de Sistema - Alejandro Ziling Zhou Lin (CTO)</i>	6
4.2.6. <i>Delegado de Protección de Datos - Iván Alexander Morán Neira (DPD)</i>	7
4.3. RESPONSABLES TIC LOCALES	7
4.4. SEGREGACIÓN DE FUNCIONES	7
4.5. PROCESO DE AUTORIZACIÓN	7
5. ANÁLISIS Y GESTIÓN DE RIESGOS	8
5.1. METODOLOGÍA	8
5.2. DECLARACIÓN DE APLICABILIDAD GLOBAL	8
5.3. CRITERIOS DE ACEPTACIÓN DE RIESGO	11
5.4. SISTEMAS DE INFORMACIÓN	11
5.4.1 <i>Bases de datos</i>	11
5.4.2 <i>Plataforma de Aprendizaje (Sistemas SaaS)</i>	16
5.4.3 <i>Infraestructura de red</i>	20
5.4.4 <i>App móvil</i>	24
5.4.5 <i>SOC interno</i>	28
6. CONTROLES DE SEGURIDAD OPERACIONALES	31
6.1. GESTIÓN DE IDENTIDADES Y CONTROL DE ACCESOS	31
6.2. PROTECCIÓN ESPECIAL DE DATOS DE MENORES	31
6.3. SEGURIDAD EN LA INFRAESTRUCTURA MULTICAMPUS	31
6.4. SEGURIDAD DEL LMS Y PLATAFORMAS EDUCATIVAS	32
6.5. OPERACIONES Y MONITORIZACIÓN	32
6.6. POLÍTICA DE CONTINUIDAD Y COPIAS DE SEGURIDAD	32
6.7. GESTIÓN DE PROVEEDORES Y TERCEROS	33
7. GESTIÓN DE INCIDENTES DE SEGURIDAD	33
7.1. OBJETIVO	33
7.2. CLASIFICACIÓN DE INCIDENTES Y TIEMPOS DE RESPUESTA	33

7.3. FLUJO DE GESTIÓN DE INCIDENTES	34
<i>Fase 1 — Detección e identificación</i>	34
<i>Fase 2 — Contención</i>	34
<i>Fase 3 — Análisis forense</i>	34
<i>Fase 4 — Erradicación</i>	34
<i>Fase 5 — Recuperación</i>	34
<i>Fase 6 — Lecciones aprendidas</i>	34
7.4. OBLIGACIONES DE NOTIFICACIÓN REGULATORIA	34
8. CONTINUIDAD DEL SERVICIO	35
8.1. ANÁLISIS DE IMPACTO EN EL NEGOCIO (BIA)	35
8.2. ESTRATEGIA DE CONTINUIDAD	35
8.3. PLAN DE CONTINUIDAD DE NEGOCIO (PCN)	35
8.4. PRUEBAS Y MANTENIMIENTO	36
9. FORMACIÓN Y CONCIENCIACIÓN	36
9.1. PLAN DE FORMACIÓN ANUAL EN SEGURIDAD	36
9.2. EJERCICIOS DE SIMULACIÓN	36
9.3. MÉTRICAS DE FORMACIÓN	37
10. AUDITORÍA Y REVISIÓN	37
10.1. AUDITORÍA INTERNA	37
10.2. AUDITORÍA EXTERNA.....	37
10.3. REVISIÓN DEL SGSI POR LA DIRECCIÓN	37
10.4. INDICADORES CLAVE DE SEGURIDAD (KPIs)	37
11. MEJORA CONTINUA.....	38
11.1. GESTIÓN DE NO CONFORMIDADES	38
11.2. CICLO PDCA APLICADO A ATHENEA	38
11.3. GESTIÓN DEL CAMBIO	38
ANEXO A – CLASIFICACIÓN DE LA INFORMACIÓN	39
ANEXO B – POLÍTICA DE USO ACEPTABLE DE LOS SISTEMAS	39
B.1 ÁMBITO.....	39
B.2 USOS PERMITIDOS.....	39
B.3 USOS PROHIBIDOS	39
B.4 PROTECCIÓN ESPECIAL DE DATOS DE MENORES	40
ANEXO C – PROCEDIMIENTO DE ALTA, MODIFICACIÓN Y BAJA DE USUARIOS	40
C.1 ALTA DE USUARIO	40
C.2 MODIFICACIÓN DE ACCESOS	40
C.3 BAJA DE USUARIO.....	40
ANEXO D – CONTACTOS DE SEGURIDAD Y CRISIS	41

1. OBJETO Y ALCANCE

1.1. Objeto

El presente documento constituye el Sistema de Gestión de la Seguridad de la Información (SGSI) de ATHENEA S.A., aprobado por el Consejo de Administración y elaborado conforme al Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad (ENS).

ATHENEA S.A. es un grupo educativo privado español constituido como sociedad anónima, con presencia en todo el territorio nacional a través de una red de 17 centros educativos que atienden a más de 25.000 alumnos, desde la etapa de Educación Infantil hasta estudios universitarios de doctorado.

La organización cuenta con más de 3.200 empleados, incluyendo un Departamento TIC con más de 200 profesionales especializados.

El SGSI define el marco normativo, organizativo y técnico que garantiza la seguridad de la información gestionada por ATHENEA S.A., preservando su confidencialidad, integridad, disponibilidad, autenticidad y trazabilidad conforme a las exigencias del ENS y la normativa de protección de datos.

1.2. Alcance

El alcance incluye la totalidad de ATHENEA S.A.: centros educativos, sedes universitarias, plataformas de enseñanza, servicios cloud, infraestructura de red, sistemas de gestión académica, personal propio, proveedores y terceros con acceso a sistemas o información corporativa, con independencia de su ubicación geográfica:

- 2 universidades: Universidad Athenea de Madrid (UAM) y Universidad Athenea de Barcelona (UAB), incluyendo todas sus facultades y escuelas.
- 5 institutos de Educación Secundaria y Bachillerato: distribuidos en diversas localidades, con programas de ESO, Bachillerato bilingüe y preparación EBAU.
- 10 centros Educativos de Primaria y Secundaria Obligatoria: que atienden a alumnos desde Educación Infantil hasta ESO.
- Infraestructura tecnológica corporativa: centros de datos propios con arquitectura cloud híbrida, red WiFi 6, plataformas LMS (Moodle y Blackboard), aplicaciones móviles para alumnos, familias y docentes, sistemas de videoconferencia y aulas híbridas, laboratorios virtuales con AR/VR y sistema de evaluación.
- Sistemas de gestión: plataformas de gestión académica, de RRHH, económico-financiera, biblioteca digital y analítica educativa con IA.
- Personal: más de 3.200 empleados, incluidos docentes, personal de administración y servicios (PAS), equipo TIC y terceros proveedores con acceso a los sistemas.
- Datos tratados: datos personales de alumnos (incluyendo menores de edad), familias, personal, datos académicos y económicos.

1.3. Categoría ENS

Tras realizar el análisis de impacto conforme al Anexo I del Real Decreto 311/2022, los sistemas de información de ATHENEA S.A. se clasifican en Categoría MEDIA. Esta determinación se fundamenta en que un eventual

incidente de seguridad podría ocasionar un perjuicio grave a un número significativo de usuarios, afectar de forma relevante la continuidad de servicios educativos críticos y derivar en responsabilidades legales de entidad, sin llegar a comprometer de manera irreversible la operatividad global de la organización.

La categorización se ha realizado considerando el impacto global del sistema, conforme a las dimensiones de seguridad según el CIDAT y no únicamente la criticidad individual de determinados activos.

Si bien algunos activos presentan niveles ALTO en determinadas dimensiones, especialmente aquellos relacionados con datos de menores, el impacto agregado del sistema se mantiene en un nivel grave pero no muy grave, lo que sitúa la clasificación en Categoría MEDIA según los criterios del ENS.

No obstante, el sistema se encuentra en un umbral elevado dentro de dicha categoría, pudiendo considerarse en términos operativos como una **categoría MEDIA con requisitos reforzados**, lo que ha motivado la implantación de medidas de seguridad adicionales propias de niveles superiores.

En este sentido, los subsistemas más críticos se encuentran bajo vigilancia reforzada y su evolución podría justificar una reclasificación a Categoría ALTA en futuros ciclos de revisión, en función de la evolución del contexto de riesgos y del impacto potencial asociado.

1.4. Principios básicos ENS aplicados

Principio ENS	Aplicación en ATHENEA, S. A.
Seguridad integral	La seguridad se trata como proceso global con elementos humanos, técnicos, jurídicos y organizativos.
Gestión basada en riesgos	Los controles se justifican por amenazas, impacto, probabilidad y criticidad de activos.
Prevención, detección, respuesta y conservación	La DdA incorpora controles preventivos, detectivos, correctivos y de recuperación.
Líneas de defensa	Se combinan capas: IAM, segmentación, EDR, NGFW, WAF, SIEM, copias y formación.
Vigilancia continua	SIEM, métricas y auditorías permiten detectar anomalías y reevaluar controles.
Diferenciación de responsabilidades	Se separan Responsable de Seguridad, Responsable del Sistema, Responsable de Información y Responsable del Servicio.

2. MARCO NORMATIVO

El documento se basa principalmente en el Real Decreto 311/2022, de 3 de mayo, que regula el Esquema Nacional de Seguridad. El ENS establece principios básicos, requisitos mínimos, categorización de sistemas, medidas de seguridad y procedimientos de conformidad. Para ATHENEA, S.A. se utiliza como marco de referencia técnico-organizativo y como base del entregable académico.

2.1. Legislación aplicable

- Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad.
- Reglamento (UE) 2016/679 (RGPD), de 27 de abril de 2016, relativo a la protección de datos personales.
- Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (LOPDGDD).
- Ley Orgánica 8/2021, de 4 de junio, de protección integral a la infancia y la adolescencia frente a la violencia (LOPVI), por la presencia de menores.
- Real Decreto Legislativo 1/1996, de 12 de abril, Ley de Propiedad Intelectual.

2.2. Normas y estándares técnicos de referencia

- ISO 27001, sistemas de gestión de la seguridad de la información.
- ISO 27002, controles de seguridad de la información.
- ISO 9001, certificación vigente en ATHENEA, S. A. sobre Sistemas de gestión de la calidad.
- ISO 14001, certificación vigente en ATHENEA, S. A. sobre Sistemas de gestión ambiental.
- MAGERIT, como metodología de análisis y gestión de riesgos de los sistemas.

3. POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN

3.1. Declaración de intenciones

El Consejo de Administración de ATHENEA, S. A. reconoce que la información constituye uno de los activos estratégicos más valiosos de la organización y que su protección adecuada es imprescindible para el cumplimiento de la misión educativa, la confianza de los alumnos, familias y colaboradores, y el respeto a las obligaciones legales vigentes.

ATHENEA, S.A. gestiona información especialmente sensible: datos personales de más de 25.000 alumnos, incluyendo un porcentaje significativo de menores de edad; datos académicos e información estratégica de investigación e innovación educativa. Esta singularidad exige un compromiso explícito y reforzado con la seguridad de la información.

La Dirección aprueba el presente Sistema de Gestión de Seguridad de la Información y se compromete a: asignar los recursos humanos, técnicos y económicos necesarios para su correcta implantación y mantenimiento; impulsar una cultura de seguridad a todos los niveles de la organización; garantizar el cumplimiento del Esquema Nacional de Seguridad en categoría Media; y promover la mejora continua del sistema.

3.2. Principios rectores

- Seguridad integral: la seguridad se abordará de forma global y transversal, coordinando los aspectos técnicos, organizativos, humanos y legales en todos los centros.
- Gestión basada en riesgos: las decisiones de inversión en seguridad se fundamentarán en el análisis y evaluación periódica de riesgos mediante metodología MAGERIT.
- Prevención, detección, respuesta y recuperación: el SOC interno garantizará la monitorización continua y la respuesta ágil ante incidentes.

- Defensa en profundidad: se implementarán múltiples capas de seguridad (red, sistema, aplicación, dato) en todos los centros.
- Protección reforzada de datos de menores: se aplicarán garantías adicionales sobre cualquier tratamiento de datos de alumnos menores de edad, conforme a la LOPDGDD y la LOPIVI.
- Función diferenciada: los roles de Responsable de Seguridad, de Sistema, de Información y de Servicio estarán claramente separados.
- Revisión continua: el SGSI se revisará con carácter anual y ante cambios significativos en la organización o el entorno de amenazas.

3.3. Objetivos de seguridad

- Garantizar la confidencialidad, integridad, disponibilidad, autenticidad y trazabilidad de la información gestionada por los 17 centros de ATHENEA, S. A.
- Proteger los datos personales de alumnos (especialmente menores), familias y personal conforme al RGPD y la LOPDGDD.
- Asegurar la continuidad de los servicios educativos esenciales (LMS, gestión académica) con los RTO y RPO definidos.
- Mantener la confianza de las familias, el alumnado, los organismos acreditadores (ISO 9001, ISO 14001) y las entidades reguladoras.
- Formar y concienciar a la totalidad del personal sobre sus responsabilidades en materia de seguridad.

3.4. Incumplimiento

El incumplimiento de la política y de los procedimientos y controles que la desarrollan podrá dar lugar a medidas disciplinarias, retirada de accesos, comunicación a responsables jerárquicos y, cuando proceda, responsabilidades legales o contractuales.

Dichas actuaciones se ejercerán de acuerdo con el convenio colectivo vigente y la normativa laboral aplicable, sin perjuicio de las responsabilidades civiles, penales o administrativas que pudieran corresponder.

4. ORGANIZACIÓN DE LA SEGURIDAD

La organización de seguridad se articula mediante roles diferenciados, comités de decisión y responsables operativos. Esta separación permite evitar conflictos de interés y garantiza que la seguridad no dependa únicamente del área que opera los sistemas.

4.1. Consejo de Administración

Máximo órgano de gobierno que aprueba la Política de Seguridad, los recursos del SGSI y recibe un informe anual de seguridad de la información. Asume la responsabilidad última ante incidentes graves o brechas de datos a gran escala.

4.2. Comité de Seguridad de la Información (CSI)

El Comité de Seguridad de Athenea, S.A., actúa como órgano supervisor, asegurando que las responsabilidades estén claramente asignadas, documentadas y comunicadas a todos los niveles de organización.

La distribución de roles se basa en el Esquema Nacional de Seguridad (ENS) y garantiza la seguridad de sistemas, datos, comunicaciones y servicios electrónicos mediante una diferenciación clara de funciones.

4.2.1. Presidente del Comité de Seguridad - Ian Isaac Santillán Cueva (CEO)

Es la máxima autoridad en la seguridad de la información de ATHENEA, S. A. Se trata del máximo responsable de la dirección y gestión de la compañía, encargado de tomar decisiones estratégicas y garantizar un buen funcionamiento. A su vez, presidirá el Comité de Seguridad e impulsará la adopción de las medidas necesarias para garantizar la protección de datos.

Entre sus funciones cabe destacar:

1. Presidir el Comité de seguridad, coordinando las reuniones y la toma de decisiones estratégicas relacionadas con la seguridad de la información.
2. Impulsar y aprobar las políticas y directrices de seguridad de la información, garantizando su alineación con los objetivos de la organización y con lo establecido en el Esquema Nacional de Seguridad (ENS).
3. Supervisar el estado general de la seguridad de la información dentro de la organización, revisando informes periódicos sobre riesgos, incidentes de seguridad y cumplimiento de la normativa.
4. Promover la implantación de medidas técnicas y organizativas adecuadas para garantizar la protección de los sistemas de información y los datos gestionados por la organización.

4.2.2. Responsable de Servicio - Francisco de Borja Rodríguez Reig (CIO)

Es la persona que tiene la autoridad de establecer los requisitos de un servicio en materia de seguridad, es decir, se encargan de establecer cuáles son los niveles de seguridad para los servicios que presta la organización. Puede ser tanto una persona física o un órgano colegiado de la entidad. Entre sus funciones cabe destacar:

1. Definir cuáles son los servicios críticos y las medidas de seguridad: debe determinar qué servicios se consideran críticos para el funcionamiento de la organización. Como accesos a áreas privadas, acceso por VPN, etc.
2. Establecer los requisitos de disponibilidad para cada servicio: el responsable debe fijar para cada servicio los requisitos de disponibilidad para garantizar su correcta prestación.
3. Trabajar de forma activa con el responsable de Seguridad para asegurar que cada servicio esté contemplado en los planes de continuidad y recuperación ante incidentes.

4.2.3. Responsable de Seguridad - Miguel Zamora Jiménez (CISO)

El responsable de Seguridad determina las decisiones para satisfacer los requisitos de seguridad de la información y de los servicios y supervisará la implantación de dichas medidas para garantizar que se satisfacen los requisitos y reportará sobre estas cuestiones. Entre sus funciones cabe destacar:

1. Determinar las medidas de seguridad aplicables, en función de las valoraciones hechas por los Responsables de la Información y los Servicios.
2. Elaborar y aprobar la Declaración de Aplicabilidad, atendiendo a los requerimientos del Responsable de la Información y del Servicio.
3. Establecer la categoría del sistema (básico, medio o alto) basándose en los criterios del ENS y atendiendo a las valoraciones del Responsable de la Información y del Servicio.
4. Comprobar que las medidas de seguridad de la información han sido adecuadamente implementadas por el Responsable de Sistema.
5. Promover la formación y concienciación en materia de seguridad de la información dentro de su ámbito de responsabilidad.

4.2.4. Responsable de Información - Aitor Jiang (CDO)

Es la persona que se encarga del uso que se haga de cierta información y, por tanto, de su protección. Hablamos de una persona que tiene la responsabilidad cuando aparece un error o una negligencia que como consecuencia deriva una brecha de seguridad que afecta tanto a la confidencialidad, integridad y/o disponibilidad de la información. Entre sus funciones cabe destacar:

1. Categorización de la información según el Anexo 1 del ENS: es el responsable de categorizar cada tipo de datos (BAJO, MEDIO o ALTO).
2. Valoración de las consecuencias de un incidente de seguridad: debe de analizar y documentar como afecta a la organización.
3. Descripción de cómo deben proteger los tipos de datos identificados: definen los controles técnicos y organizativos necesarios para proteger la información según su nivel de categorización.
4. Aprobar políticas de seguridad y sus actualizaciones.

4.2.5. Responsable de Sistema - Alejandro Ziling Zhou Lin (CTO)

Es la persona encargada de garantizar la operatividad, disponibilidad y el buen funcionamiento de los sistemas de información propios de la organización. Además, también se encarga de supervisar la contratación y uso de sistemas de información de terceros (acceso a repositorios, servicios externos, etc.). Entre sus funciones caben destacar:

1. Operación y mantenimiento de los sistemas de información: garantizar que los servidores, base de datos y aplicaciones funcionen correctamente, aplicando actualizaciones del software, parches de seguridad, etc.
2. Implementar y supervisar medidas de seguridad: implementar protección contra el virus, firewalls, control de acceso, etc.
3. Gestión de incidentes y respuestas a las vulnerabilidades: debe detectar y actuar ante incidentes que afectan a los sistemas, aplicando sus respectivas medidas y además se debe notificar al Responsable de Seguridad para su análisis y seguimiento.
4. Adopción de las medidas correctoras derivadas de las auditorías de seguridad.

4.2.6. Delegado de Protección de Datos - Iván Alexander Morán Neira (DPD)

Es la persona encargada de supervisar el cumplimiento de la normativa vigente en materia de protección de datos personales dentro de su organización. Su función principal es supervisar que el tratamiento de los datos personales se realice en conforme al Reglamento General de Protección de Datos (RGPD) y demás normativa aplicable. Entre sus funciones caben destacar:

1. Informar y asesorar a la organización y a sus empleados sobre las obligaciones derivadas de la normativa de protección de datos.
2. Supervisar el cumplimiento de la normativa aplicable y de las políticas internas de protección de datos, incluyendo la asignación de responsabilidades, la concienciación y formación del personal que participa en operaciones de tratamiento de datos.
3. Cooperar con la autoridad de control competente y actuar como punto de contacto para cuestiones relacionadas con el tratamiento de datos.
4. Supervisar y asesorar en la gestión de incidentes de seguridad que puedan implicar una brecha de seguridad de datos personales. Este colaborará con el Responsable de Seguridad y el Responsable del Sistema para evaluar el impacto del incidente, determinando las medidas correctoras y garantizar el cumplimiento de las obligaciones legales en base a la normativa vigente.

4.3. Responsables TIC locales

Cada centro educativo cuenta con un Responsable TIC local encargado de la infraestructura tecnológica del centro, aplica las políticas y procedimientos del SGSI.

Actúa como primer punto de contacto ante incidentes locales, escalando al Responsable de Seguridad cuando sea necesario.

4.4. Segregación de funciones

En cumplimiento del artículo 11.2 del ENS se garantiza la independencia entre los roles de Responsable de Seguridad, Sistema y Servicio, recayendo necesariamente en personas distintas.

Esta segregación se verifica en el modelo organizativo de ATHENEA, S.A., donde el Responsable de Seguridad mantiene una dependencia funcional directa del Comité de Seguridad, asegurando que su labor no se vea comprometida por necesidades operativas del departamento TIC.

4.5. Proceso de autorización

Todo acceso a los sistemas de información de ATHENEA, S. A. requerirá autorización expresa del Responsable de Servicio y validación técnica del Responsable de Seguridad, bajo el principio de “mínimo privilegio”.

Las altas, bajas y modificaciones de permisos quedarán registradas en el sistema de gestión de identidades (IAM) corporativo para asegurar la trazabilidad.

5. ANÁLISIS Y GESTIÓN DE RIESGOS

5.1. Metodología

La metodología combina criterios normativos ENS, análisis de riesgos y adecuación práctica al contexto de ATHENEA, S.A. La selección de controles parte del Anexo II del RD 311/2022 y se ajusta a la categoría MEDIA, incorporando medidas adicionales cuando la naturaleza de los datos, los servicios o las amenazas lo justifica.

1. Identificación y valoración de activos.
2. Determinación de dimensiones CIDAT y categoría ENS.
3. Revisión de principios básicos y requisitos mínimos del RD 311/2022.
4. Selección de medidas organizativas, operacionales y de protección del Anexo II.
5. Justificación de aplicabilidad en función de riesgos generales: phishing, ransomware, acceso no autorizado, fuga de datos, indisponibilidad, errores cloud y cadena de suministro.
6. Definición de evidencias, responsables, auditoría y mejora continua.

5.2. Declaración de Aplicabilidad Global

Esta Declaración de Aplicabilidad define el catálogo general de controles del ENS aplicables a toda la organización. Cada sistema concreto dispone de su propia tabla específica que adapta esta misma en función de su naturaleza, tecnología y riesgos particulares.

Criterio de lectura:

1. Media – obligatoria indica exigencia derivada de la categoría o dimensión de seguridad
2. Adicional por riesgo indica aplicación voluntaria/reforzada por el contexto de ATHENEA
3. Parcial" o "Planificada indica que la medida requiere maduración o evidencias adicionales

Código	Control ENS	Aplica	Nivel / Refuerzo	Estado	Justificación global / evidencia prevista
org.1	Política de seguridad	Sí	Media - obligatoria	Implantada	Política corporativa aprobada por Dirección. Define misión educativa, marco legal, roles, comité, documentación y riesgos derivados del tratamiento de datos personales.
org.2	Normativa de seguridad	Sí	Media - obligatoria	Implantada	Normas internas de uso aceptable, clasificación de la información, dispositivos móviles, teletrabajo, IA, correo y tratamiento de datos de menores.
org.3	Procedimientos de seguridad	Sí	Media - obligatoria	Implantada	Procedimientos comunes para operación, reporte de anomalías, copias, etiquetado, transmisión segura, gestión de cambios e incidentes en los 17 centros.
org.4	Proceso de autorización	Sí	Media - obligatoria	Implantada	Autorización formal para altas de usuarios, entrada de sistemas en producción, servicios cloud, soportes, comunicaciones y proveedores.
op.pl.1	Análisis de riesgos	Sí	Media + R1	Implantada	Análisis semiformal MAGERIT con activos, amenazas, salvaguardas y riesgo residual. Revisión anual y ante cambios relevantes.
op.pl.2	Arquitectura de seguridad	Sí	Media + R1	Implantada	Arquitectura documentada con líneas de defensa: IAM, segmentación, NGFW, DMZ, SIEM, EDR, cloud híbrido y controles de datos sensibles.
op.pl.3	Adquisición de nuevos componentes	Sí	Media - obligatoria	Implantada	Proceso de aprobación TIC/RSI antes de adquirir LMS, servicios cloud, aplicaciones educativas o componentes de seguridad.

op.pl.4	Dimensionamiento / gestión de la capacidad	Sí	Dimensión D - Media + R1	Implantada	Capacidad monitorizada para LMS, ERP, WiFi, M365 y cloud. Previsión de demanda en exámenes, matrículas e inicio de curso.
op.pl.5	Componentes certificados	Sí	Media - obligatoria	Parcial	Preferencia por productos y servicios cualificados en CPSTIC/CCN o con certificaciones reconocidas. Plan de madurez para proveedores cloud y seguridad.
op.acc.1	Identificación	Sí	T/A Media + R1	Implantada	Identificadores únicos y nominales en IAM corporativo; separación de perfiles alumno, docente, PAS, TIC y administrador.
op.acc.2	Requisitos de acceso	Sí	C/I/T/A Media	Implantada	Accesos protegidos por mínimo privilegio, necesidad de conocer y matrices de permisos por perfil profesional y servicio.
op.acc.3	Segregación de funciones y tareas	Sí	C/I/T/A Media	Implantada	Separación entre RSI, responsable del sistema, operación, auditoría, desarrollo y aprobación de cambios críticos.
op.acc.4	Gestión de derechos de acceso	Sí	C/I/T/A Media	Implantada	Altas, modificaciones y bajas mediante IAM; revisión semestral; deshabilitación de accesos tras baja o cambio de rol.
op.acc.5	Autenticación usuarios externos	Sí	C/I/T/A Media + MFA/registro	Implantada	Familias, alumnado universitario, proveedores y terceros acceden con MFA, registro de accesos y condiciones específicas según perfil.
op.acc.6	Autenticación usuarios internos	Sí	C/I/T/A Media + MFA	Implantada	MFA para personal, TIC y administradores; bloqueo de sesión, contraseñas robustas y controles adicionales para privilegios elevados.
op.exp.1	Inventario de activos	Sí	Media - obligatoria	Implantada	CMDb corporativa con activos de información, software, hardware, redes, cloud, personal clave e instalaciones.
op.exp.2	Configuración de seguridad	Sí	Media - obligatoria	Implantada	Bastionado de servidores, endpoints, M365, LMS, firewalls y servicios cloud mediante guías CCN-STIC/CIS.
op.exp.3	Gestión de configuración de seguridad	Sí	Media + R1	Implantada	Repositorio de configuraciones, control de versiones, revisión de cambios y validación previa a producción.
op.exp.4	Mantenimiento y actualizaciones de seguridad	Sí	Media + R1	Implantada	Parches críticos en <=72h, altos en <=15 días, medios en <=60 días. Priorización por exposición y criticidad.
op.exp.5	Gestión de cambios	Sí	Media - obligatoria	Implantada	CAB corporativo, pruebas en preproducción y aprobación formal para cambios en LMS, ERP, IAM, red y cloud.
op.exp.6	Protección frente a código dañino	Sí	Media + R1/R2	Implantada	EDR corporativo, antimalware, bloqueo de macros, sandboxing de adjuntos y monitorización
op.exp.7	Gestión de incidentes	Sí	Media + R1/R2	Implantada	Procedimiento P1-P4, escalado a RSI/DPD/Dirección, registro de evidencias y notificación regulatoria cuando proceda.
op.exp.8	Registro de la actividad	Sí	T Media + refuerzos	Implantada	Logs centralizados en SIEM: IAM, LMS, VPN, firewall, EDR, servidores, BBDD y servicios cloud. Retención proporcional.
op.exp.9	Registro de gestión de incidentes	Sí	Media - obligatoria	Implantada	Ticketing integrad. Registro de triaje, contención, análisis, erradicación, recuperación y lecciones aprendidas.
op.exp.10	Protección de claves criptográficas	Sí	Media + R1	Implantada	Custodia de claves en almacenes seguros/HSM cloud cuando aplique; rotación, separación de funciones y acceso restringido.
op.ext.1	Contratación y acuerdos de nivel de servicio	Sí	Media - obligatoria	Implantada	Contratos con cláusulas de seguridad, confidencialidad, RGPD, auditoría, notificación de incidentes y devolución/destrucción de datos.
op.ext.2	Gestión diaria de proveedores	Sí	Media - obligatoria	Implantada	Revisión periódica de proveedores críticos: LMS, cloud, M365, conectividad y soporte externo.
op.ext.3	Protección de la cadena de suministro	Sí	Adicional por riesgo	Parcial	Para proveedores cloud/LMS y subcontratistas. Medida aplicada por dependencia de terceros
op.ext.4	Interconexión de sistemas	Sí	Media - obligatoria	Implantada	Control de integraciones entre sedes, cloud, LMS, ERP, M365, VPN y redes de invitados. Revisión de puntos de interconexión.
op.nub.1	Protección de servicios en la nube	Sí	Media + R1	Implantada	Configuración segura de AWS/Azure/M365, cifrado, IAM cloud, registro de actividad, revisión de permisos y respaldo contractual.

op.cont.1	Análisis de impacto	Sí	Dimensión D - Media	Implantada	BIA corporativo para LMS, ERP, correo, WiFi, Internet, sistemas y procesos académicos críticos.
op.cont.2	Plan de continuidad	Sí	Adicional por riesgo	Implantada	PCN aplicado, aunque no siempre sea exigible en Media, por continuidad docente, evaluación, matrícula y comunicación familias.
op.cont.3	Pruebas periódicas	Sí	Adicional por riesgo	Implantada	Simulacro anual y pruebas trimestrales de restauración. Participan TIC central y responsables TIC locales.
op.cont.4	Medios alternativos	Sí	Adicional por riesgo	Implantada	Conectividad redundante, modo degradado LMS, copias offsite, contingencia 4G/5G y operación alternativa por centro.
op.mon.1	Detección de intrusión	Sí	Media + R1	Implantada	Reglas SIEM orientadas a ransomware, phishing, DDoS y explotación del LMS.
op.mon.2	Sistema de métricas	Sí	Media + R1/R2	Implantada	Cuadro de mando semestral: parches, incidentes, MFA, formación, vulnerabilidades, backups, proveedores y cobertura SIEM.
op.mon.3	Vigilancia	Sí	Media + R1/R2	Implantada	Monitorización continua por, threat intelligence, detección de anomalías y revisión periódica de vulnerabilidades.
mp.if.1	Áreas separadas y control de acceso	Sí	Media - obligatoria	Implantada	Zonas controladas y acceso restringido al personal autorizado y registro de entradas.
mp.if.2	Identificación de las personas	Sí	Media - obligatoria	Implantada	Tarjeta corporativa, control de visitantes y verificación de identidad para acceso a zonas sensibles.
mp.if.3	Acondicionamiento de locales	Sí	Media - obligatoria	Implantada	Climatización, sensores ambientales, control de humedad, detección de humo y mantenimiento preventivo en instalaciones
mp.if.4	Energía eléctrica	Sí	D Media + R1	Implantada	SAI, grupo electrógeno y redundancia eléctrica para sedes principales.
mp.if.5	Protección frente a incendios	Sí	Media - obligatoria	Implantada	Detección y extinción automática y procedimientos de evacuación y revisión periódica.
mp.if.6	Protección frente a inundaciones	Sí	D Media	Implantada	Sensores de agua, ubicación elevada de equipos, revisión de riesgos físicos y plan de contingencia.
mp.if.7	Registro de entrada/salida de equipamiento	Sí	Media - obligatoria	Implantada	Registro de salida, entrada, reparación y baja de equipos TIC, soportes y dispositivos móviles corporativos.
mp.per.1	Caracterización del puesto de trabajo	Sí	Media - obligatoria	Implantada	Perfiles de puesto con requisitos de seguridad, confidencialidad y acceso según función docente, PAS, TIC o directiva.
mp.per.2	Deberes y obligaciones	Sí	Media + R1	Implantada	AUP, confidencialidad, obligaciones RGPD, deber de custodia de credenciales y régimen disciplinario.
mp.per.3	Concienciación	Sí	Media - obligatoria	Implantada	Formación anual, simulaciones de phishing y comunicación de buenas prácticas a todo el personal.
mp.per.4	Formación	Sí	Media - obligatoria	Implantada	Formación específica para TIC en ENS, gestión de incidentes, bastionado, forense básica y protección de menores.
mp.eq.1	Puesto de trabajo despejado	Sí	Media + R1	Implantada	Política de escritorio limpio, bloqueo de pantallas y tratamiento seguro de documentación física.
mp.eq.2	Bloqueo de puesto de trabajo	Sí	A Media	Implantada	Bloqueo automático a 5 minutos, autenticación para desbloqueo y controles GPO/MDM.
mp.eq.3	Protección de dispositivos portátiles	Sí	Media - obligatoria	Implantada	Cifrado completo, MDM, EDR, VPN, borrado remoto y prohibición de almacenamiento local no autorizado.
mp.eq.4	Otros dispositivos conectados a la red	Sí	C Media + R1	Implantada	Segmentación IoT/VR/AR, inventario de dispositivos y autorización previa antes de conexión a red corporativa.
mp.com.1	Perímetro seguro	Sí	Media - obligatoria	Implantada	NGFW, DMZ, reglas de filtrado, proxy, WAF y revisión de exposición externa.
mp.com.2	Protección de la confidencialidad	Sí	C Media + R1	Implantada	TLS 1.3, VPN, cifrado de enlaces SD-WAN, protección de datos de menores
mp.com.3	Protección de integridad y autenticidad	Sí	I/A Media + R1/R2	Implantada	Certificados, firma electrónica, control de integridad, hash de evidencias y validación de comunicaciones.
mp.com.4	Separación de flujos de información en red	Sí	Media + R1/R2/R3	Implantada	VLAN y políticas separadas para alumnos, docentes/PAS, servidores, gestión, invitados, IoT/VR y proveedores.

mp.si.1	Marcado de soportes	Sí	C Media	Implantada	Etiquetado de soportes según clasificación: Público, Uso Interno, Confidencial y Secreto.
mp.si.2	Criptografía	Sí	C/I Media	Implantada	AES-256 en reposo, TLS 1.3 en tránsito, claves gestionadas y políticas de uso criptográfico.
mp.si.3	Custodia	Sí	Media - obligatoria	Implantada	Custodia de soportes y copias en ubicaciones protegidas, con acceso restringido y trazabilidad.
mp.si.4	Transporte	Sí	Media - obligatoria	Implantada	Cifrado de soportes extraíbles, registro de movimientos y transporte por canales autorizados.
mp.si.5	Borrado y destrucción	Sí	C Media + R1	Implantada	Borrado seguro lógico y destrucción certificada de soportes al final de vida útil.
mp.sw.1	Desarrollo de aplicaciones	Sí	Media + R1/R2/R3/R4	Implantada	SSDLC: revisión de código, SAST/DAST, gestión de secretos, segregación de entornos y prohibición de datos reales en pruebas.
mp.sw.2	Aceptación y puesta en servicio	Sí	Media + R1	Implantada	Pruebas funcionales y de seguridad, aprobación de RSI y responsable del servicio antes de producción.
mp.info.1	Datos personales	Sí	Media - obligatoria	Implantada	RAT, EIPD para menores, minimización, base jurídica, derechos y medidas RGPD/LOPDGDD.
mp.info.2	Calificación de la información	Sí	C Media	Implantada	Clasificación corporativa de información y reglas de tratamiento por nivel.
mp.info.3	Firma electrónica	Sí	I/A Media + refuerzos	Implantada	Firma electrónica en documentos académicos, autorizaciones, actas y evidencias de auditoría relevantes.
mp.info.4	Sellos de tiempo	Sí	Adicional por riesgo	Planificada	Sellado temporal para evidencias críticas, registros de auditoría y documentos académicos con efectos probatorios.
mp.info.5	Limpieza de documentos	Sí	C Media	Implantada	Revisión de metadatos, anonimización cuando proceda y control de documentos antes de publicación o envío externo.
mp.info.6	Copias de seguridad	Sí	D Media + R1	Implantada	Copias cifradas, pruebas trimestrales de restauración
mp.s.1	Protección del correo electrónico	Sí	Media - obligatoria	Implantada	Antiphishing, sandboxing, formación y reporte rápido
mp.s.2	Protección de servicios y aplicaciones web	Sí	Media + R1/R2	Implantada	WAF, HTTPS, escaneos mensuales, pentest anual y bastionado de LMS, app móvil y portales.
mp.s.3	Protección de la navegación web	Sí	Media - obligatoria	Implantada	Proxy, filtrado DNS/URL, inspección de malware y bloqueo de categorías de riesgo.
mp.s.4	Protección frente a denegación de servicio	Sí	D Media	Implantada	Protección AntiDDoS en CDN/cloud, reglas perimetrales y planes de escalado ante indisponibilidad.

5.3. Criterios de aceptación de riesgo

El Comité de Seguridad de ATHENEA S.A. ha establecido como umbral de riesgo aceptable el nivel MEDIO. Todo riesgo clasificado como ALTO o MUY ALTO exigirá un plan de tratamiento documentado con responsable, medidas concretas y plazo de implantación. Los riesgos sobre datos de menores no son susceptibles de aceptación: deberán ser mitigados hasta alcanzar un nivel de riesgo residual BAJO o MEDIO.

5.4. Sistemas de información

5.4.1 Bases de datos

Los datos de menores requieren salvaguardas reforzadas, aunque el sistema global se categorice como MEDIA. ATHENEA aplicará minimización, cifrado, segmentación, autorización reforzada, trazabilidad completa y evaluaciones de impacto cuando proceda.

INVENTARIO Y VALORACIÓN DE ACTIVOS

ID	Nombre del activo	Tipo	Confidenc.	Integrid.	Disponib.	Autenticid.	Trazabil.
INF-01	Expedientes académicos y calificaciones oficiales	Información	Alta	Alta	Media	Alta	Alta
INF-02	Datos personales de alumnos y menores de edad	Información	Alta	Media	Baja	Media	Alta
INF-03	Datos personales de familias y tutores legales	Información	Alta	Media	Baja	Media	Media
INF-04	Datos de matrícula y tasas académicas	Software	Alta	Alta	Media	Media	Alta
SW-01	ERP de gestión académica corporativo	Software	Alta	Alta	Alta	Alta	Alta
SW-02	Portal web de consulta para alumnos y familias	Software	Media	Alta	Alta	Alta	Media
HW-01	Servidores del ERP académico	Hardware	Baja	Alta	Alta	Baja	Baja
HW-02	Base de datos de expedientes y calificaciones	Hardware	Alta	Alta	Alta	Media	Alta

IDENTIFICACIÓN Y EVALUACIÓN DE AMENAZAS

Activo	Amenaza	Probabilid. (justificación)	Impacto (consecuencia)	Efecto (resultado, probab + impacto)	Tratamiento (tecnología, normativa o personas)	Prioridad
INF-01	Manipulación fraudulenta de calificaciones oficiales	Baja, Requiere acceso privilegiado al ERP. La firma electrónica cualificada y los logs inmutables hacen muy difícil la manipulación no detectada.	Alteración o corrupción de registros académicos, pérdida de integridad de las calificaciones y falta de fiabilidad en los datos almacenados.	Invalidación de títulos universitarios. Responsabilidad legal ante afectados y organismos acreditadores. Daño reputacional grave.	T: Firma cualificada en modificaciones. Logs WORM. N: Doble aprobación para cambios en calificaciones. P: Concienciación PAS.	2- Alta
INF-02	Filtración de datos personales de menores de edad	Media, Entornos educativos con numerosos usuarios y distintos niveles de acceso. El ERP tiene gran	Acceso no autorizado y exposición de datos sensibles, comprometiendo la confidencialidad	Sanciones RGPD muy graves. Daño irreparable para los menores afectados. Obligación de notificación a AEPD y familias.	T: BBDD menores en segmento aislado, cifrado AES-256. N: EIPD realizada. P: Formación	1- Crítica

		superficie de exposición interna.	de la información almacenada.		específica del PAS académico.	
SW-01	Acceso no autorizado mediante cuenta PAS comprometida (phishing)	Alta, El phishing es el vector más frecuente. El PAS académico accede habitualmente al ERP desde equipos con distintos niveles de seguridad.	Acceso no autorizado y exposición de datos sensibles, comprometiendo la confidencialidad de la información almacenada.	Acceso a expedientes y datos de menores. Posibilidad de modificar calificaciones o extraer datos de forma masiva.	T: MFA obligatorio en ERP. N: AUP firmada. P: 3 simulaciones de phishing anuales.	1-Crítica
SW-01	Indisponibilidad del ERP en periodo de matrícula o exámenes	Media, Dependencia de la arquitectura cloud híbrida. Los picos de carga en inicio de curso y convocatorias pueden saturar el sistema.	Acceso no autorizado y exposición de datos sensibles, comprometiendo la confidencialidad de la información almacenada.	Imposibilidad de tramitar matrículas o introducir calificaciones. Impacto sobre todos los centros simultáneamente.	T: Arquitectura activo-activo con failover. Backups cada 6h. N: PCN con RTO 4h. P: IT Ops formado en recuperación.	2- Alta
HW-01	Insider malicioso con acceso privilegiado al ERP	Baja, Riesgo bajo por la segregación de funciones y los controles de acceso, pero el PAS con privilegios elevados podría modificar expedientes.	Acceso no autorizado y exposición de datos sensibles, comprometiendo la confidencialidad de la información almacenada.	Modificación de expedientes con efectos jurídicos permanentes. Difícil detección si no hay logs completos.	T: Logs inmutables, alertas SIEM en modificaciones masivas. N: Segregación de funciones. P: Revisión semestral de accesos.	2- Alta

4. DECLARACIÓN DE APLICABILIDAD (DB)

Código	Control ENS	Aplica	Nivel / refuerzo	Estado	Justificación global / evidencia prevista
org.1	Política de seguridad	Sí	Media - obligatoria	Implantada	Política corporativa aprobada por Dirección. Define misión educativa, marco legal, roles, comité, documentación y riesgos derivados del tratamiento de datos personales.
org.2	Normativa de seguridad	Sí	Media - obligatoria	Implantada	Normas internas de uso aceptable, clasificación de la información, dispositivos móviles, teletrabajo, IA, correo y tratamiento de datos de menores.
org.3	Procedimientos de seguridad	Sí	Media - obligatoria	Implantada	Procedimientos comunes para operación, reporte de anomalías, copias, etiquetado, transmisión segura, gestión de cambios e incidentes en los 17 centros.
org.4	Proceso de autorización	Sí	Media - obligatoria	Implantada	Autorización formal para altas de usuarios, entrada de sistemas en producción, servicios cloud, soportes, comunicaciones y proveedores.
op.pl.1	Análisis de riesgos	Sí	Media + R1	Implantada	Análisis semiformal MAGERIT con activos, amenazas, salvaguardas y riesgo residual. Revisión anual y ante cambios relevantes.
op.pl.2	Arquitectura de seguridad	Sí	Media + R1	Implantada	Arquitectura documentada con líneas de defensa: IAM, segmentación, NGFW, DMZ, SIEM, EDR, cloud híbrido y controles de datos sensibles.
op.pl.3	Adquisición de nuevos componentes	Sí	Media - obligatoria	Implantada	Proceso de aprobación TIC/RSI antes de adquirir LMS, servicios cloud, aplicaciones educativas o componentes de seguridad.
op.pl.4	Dimensionamiento / gestión de la capacidad	Sí	Dimensión D - Media + R1	Implantada	Capacidad monitorizada para LMS, ERP, WiFi, M365 y cloud. Previsión de demanda en exámenes, matrículas e inicio de curso.
op.pl.5	Componentes certificados	Sí	Media - obligatoria	Parcial	Preferencia por productos y servicios cualificados en CPSTIC/CCN o con certificaciones reconocidas. Plan de madurez para proveedores cloud y seguridad.
op.acc.1	Identificación	Sí	T/A Media + R1	Implantada	Identificadores únicos y nominales en IAM corporativo; separación de perfiles alumno, docente, PAS, TIC y administrador.
op.acc.2	Requisitos de acceso	Sí	C/I/T/A Media	Implantada	Accesos protegidos por mínimo privilegio, necesidad de conocer y matrices de permisos por perfil profesional y servicio.
op.acc.3	Segregación de funciones y tareas	Sí	C/I/T/A Media	Implantada	Separación entre RSI, responsable del sistema, operación, auditoría, desarrollo y aprobación de cambios críticos.
op.acc.4	Gestión de derechos de acceso	Sí	C/I/T/A Media	Implantada	Altas, modificaciones y bajas mediante IAM; revisión semestral; deshabilitación de accesos tras baja o cambio de rol.
op.acc.5	Autenticación usuarios externos	Sí	C/I/T/A Media + MFA/registro	Implantada	Familias, alumnado universitario, proveedores y terceros acceden con MFA, registro de accesos y condiciones específicas según perfil.
op.acc.6	Autenticación usuarios internos	Sí	C/I/T/A Media + MFA	Implantada	MFA para personal, TIC y administradores; bloqueo de sesión, contraseñas robustas y controles adicionales para privilegios elevados.
op.exp.1	Inventario de activos	Sí	Media - obligatoria	Implantada	CMDB corporativa con activos de información, software, hardware, redes, cloud, personal clave e instalaciones.
op.exp.2	Configuración de seguridad	Sí	Media - obligatoria	Implantada	Bastionado de servidores, endpoints, M365, LMS, firewalls y servicios cloud mediante guías CCN-STIC/CIS.
op.exp.3	Gestión de configuración de seguridad	Sí	Media + R1	Implantada	Repositorio de configuraciones, control de versiones, revisión de cambios y validación previa a producción.
op.exp.4	Mantenimiento y actualizaciones de seguridad	Sí	Media + R1	Implantada	Parches críticos en <=72h, altos en <=15 días, medios en <=60 días. Priorización por exposición y criticidad.
op.exp.5	Gestión de cambios	Sí	Media - obligatoria	Implantada	CAB corporativo, pruebas en preproducción y aprobación formal para cambios en LMS, ERP, IAM, red y cloud.
op.exp.6	Protección frente a código dañino	Sí	Media + R1/R2	Implantada	EDR corporativo, antimalware, bloqueo de macros, sandboxing de adjuntos y monitorización
op.exp.7	Gestión de incidentes	Sí	Media + R1/R2	Implantada	Procedimiento P1-P4, escalado a RSI/DPD/Dirección, registro de evidencias y notificación regulatoria cuando proceda.
op.exp.8	Registro de la actividad	Sí	T Media + refuerzos	Implantada	Logs centralizados en SIEM: IAM, LMS, VPN, firewall, EDR, servidores, BBDD y servicios cloud. Retención proporcional.
op.exp.9	Registro de gestión de incidentes	Sí	Media - obligatoria	Implantada	Ticketing integrad. Registro de triaje, contención, análisis, erradicación, recuperación y lecciones aprendidas.
op.exp.10	Protección de claves criptográficas	Sí	Media + R1	Implantada	Custodia de claves en almacenes seguros/HSM cloud cuando aplique; rotación, separación de funciones y acceso restringido.
op.ext.1	Contratación y acuerdos de nivel de servicio	Sí	Media - obligatoria	Implantada	Contratos con cláusulas de seguridad, confidencialidad, RGPD, auditoría, notificación de incidentes y devolución/destrucción de datos.
op.ext.2	Gestión diaria de proveedores	Sí	Media - obligatoria	Implantada	Revisión periódica de proveedores críticos: LMS, cloud, M365, conectividad y soporte externo.
op.ext.3	Protección de la cadena de suministro	Sí	Adicional por riesgo	Parcial	Para proveedores cloud/LMS y subcontratistas. Medida aplicada por dependencia de terceros
op.ext.4	Interconexión de sistemas	Sí	Media - obligatoria	Implantada	Control de integraciones entre sedes, cloud, LMS, ERP, M365, VPN y redes de invitados. Revisión de puntos de interconexión.
op.nub.1	Protección de servicios en la nube	Sí	Media + R1	Implantada	Configuración segura de AWS/Azure/M365, cifrado, IAM cloud, registro de actividad, revisión de permisos y respaldo contractual.
op.cont.1	Análisis de impacto	Sí	Dimensión D - Media	Implantada	BIA corporativo para LMS, ERP, correo, WiFi, Internet, sistemas y procesos académicos críticos.
op.cont.2	Plan de continuidad	Sí	Adicional por riesgo	Implantada	PCN aplicado, aunque no siempre sea exigible en Media, por continuidad docente, evaluación, matrícula y comunicación familias.
op.cont.3	Pruebas periódicas	Sí	Adicional por riesgo	Implantada	Simulacro anual y pruebas trimestrales de restauración. Participan TIC central y responsables TIC locales.
op.cont.4	Medios alternativos	Sí	Adicional por riesgo	Implantada	Conectividad redundante, modo degradado LMS, copias offsite, contingencia 4G/5G y operación alternativa por centro.
op.mon.1	Detección de intrusión	Sí	Media + R1	Implantada	Reglas SIEM orientadas a ransomware, phishing, DDoS y explotación del LMS.

Código	Control ENS	Aplica	Nivel / refuerzo	Estado	Justificación global / evidencia prevista
op.mon.2	Sistema de métricas	Sí	Media + R1/R2	Implantada	Cuadro de mando semestral: parches, incidentes, MFA, formación, vulnerabilidades, backups, proveedores y cobertura SIEM.
op.mon.3	Vigilancia	Sí	Media + R1/R2	Implantada	Monitorización continua por, threat intelligence, detección de anomalías y revisión periódica de vulnerabilidades.
mp.if.1	Áreas separadas y control de acceso	Sí	Media - obligatoria	Implantada	Zonas controladas y acceso restringido al personal autorizado y registro de entradas.
mp.if.2	Identificación de las personas	Sí	Media - obligatoria	Implantada	Tarjeta corporativa, control de visitantes y verificación de identidad para acceso a zonas sensibles.
mp.if.3	Acondicionamiento de locales	Sí	Media - obligatoria	Implantada	Climatización, sensores ambientales, control de humedad, detección de humo y mantenimiento preventivo en instalaciones
mp.if.4	Energía eléctrica	Sí	D Media + R1	Implantada	SAI, grupo electrógeno y redundancia eléctrica para sedes principales.
mp.if.5	Protección frente a incendios	Sí	Media - obligatoria	Implantada	Detección y extinción automática y procedimientos de evacuación y revisión periódica.
mp.if.6	Protección frente a inundaciones	Sí	D Media	Implantada	Sensores de agua, ubicación elevada de equipos, revisión de riesgos físicos y plan de contingencia.
mp.if.7	Registro de entrada/salida de equipamiento	Sí	Media - obligatoria	Implantada	Registro de salida, entrada, reparación y baja de equipos TIC, soportes y dispositivos móviles corporativos.
mp.per.1	Caracterización del puesto de trabajo	Sí	Media - obligatoria	Implantada	Perfiles de puesto con requisitos de seguridad, confidencialidad y acceso según función docente, PAS, TIC o directiva.
mp.per.2	Deberes y obligaciones	Sí	Media + R1	Implantada	AUP, confidencialidad, obligaciones RGPD, deber de custodia de credenciales y régimen disciplinario.
mp.per.3	Concienciación	Sí	Media - obligatoria	Implantada	Formación anual, simulaciones de phishing y comunicación de buenas prácticas a todo el personal.
mp.per.4	Formación	Sí	Media - obligatoria	Implantada	Formación específica para TIC en ENS, gestión de incidentes, bastionado, forense básica y protección de menores.
mp.eq.1	Puesto de trabajo despejado	Sí	Media + R1	Implantada	Política de escritorio limpio, bloqueo de pantallas y tratamiento seguro de documentación física.
mp.eq.2	Bloqueo de puesto de trabajo	Sí	A Media	Implantada	Bloqueo automático a 5 minutos, autenticación para desbloqueo y controles GPO/MDM.
mp.eq.3	Protección de dispositivos portátiles	Sí	Media - obligatoria	Implantada	Cifrado completo, MDM, EDR, VPN, borrado remoto y prohibición de almacenamiento local no autorizado.
mp.eq.4	Otros dispositivos conectados a la red	Sí	C Media + R1	Implantada	Segmentación IoT/VR/AR, inventario de dispositivos y autorización previa antes de conexión a red corporativa.
mp.com.1	Perímetro seguro	Sí	Media - obligatoria	Implantada	NGFW, DMZ, reglas de filtrado, proxy, WAF y revisión de exposición externa.
mp.com.2	Protección de la confidencialidad	Sí	C Media + R1	Implantada	TLS 1.3, VPN, cifrado de enlaces SD-WAN, protección de datos de menores
mp.com.3	Protección de integridad y autenticidad	Sí	I/A Media + R1/R2	Implantada	Certificados, firma electrónica, control de integridad, hash de evidencias y validación de comunicaciones.
mp.com.4	Separación de flujos de información en red	Sí	Media + R1/R2/R3	Implantada	VLAN y políticas separadas para alumnos, docentes/PAS, servidores, gestión, invitados, IoT/VR y proveedores.
mp.si.1	Marcado de soportes	Sí	C Media	Implantada	Etiquetado de soportes según clasificación: Público, Uso Interno, Confidencial y Secreto.
mp.si.2	Criptografía	Sí	C/I Media	Implantada	AES-256 en reposo, TLS 1.3 en tránsito, claves gestionadas y políticas de uso criptográfico.
mp.si.3	Custodia	Sí	Media - obligatoria	Implantada	Custodia de soportes y copias en ubicaciones protegidas, con acceso restringido y trazabilidad.
mp.si.4	Transporte	Sí	Media - obligatoria	Implantada	Cifrado de soportes extraíbles, registro de movimientos y transporte por canales autorizados.
mp.si.5	Borrado y destrucción	Sí	C Media + R1	Implantada	Borrado seguro lógico y destrucción certificada de soportes al final de vida útil.
mp.sw.1	Desarrollo de aplicaciones	Sí	Media + R1/R2/R3/R4	Implantada	SSDLC: revisión de código, SAST/DAST, gestión de secretos, segregación de entornos y prohibición de datos reales en pruebas.
mp.sw.2	Aceptación y puesta en servicio	Sí	Media + R1	Implantada	Pruebas funcionales y de seguridad, aprobación de RSI y responsable del servicio antes de producción.
mp.info.1	Datos personales	Sí	Media - obligatoria	Implantada	RAT, EIPD para menores, minimización, base jurídica, derechos y medidas RGPD/LOPDGDD.
mp.info.2	Calificación de la información	Sí	C Media	Implantada	Clasificación corporativa de información y reglas de tratamiento por nivel.
mp.info.3	Firma electrónica	Sí	I/A Media + refuerzos	Implantada	Firma electrónica en documentos académicos, autorizaciones, actas y evidencias de auditoría relevantes.
mp.info.4	Sellos de tiempo	Sí	Adicional por riesgo	Planificada	Sellado temporal para evidencias críticas, registros de auditoría y documentos académicos con efectos probatorios.
mp.info.5	Limpieza de documentos	Sí	C Media	Implantada	Revisión de metadatos, anonimización cuando proceda y control de documentos antes de publicación o envío externo.
mp.info.6	Copias de seguridad	Sí	D Media + R1	Implantada	Copias cifradas, pruebas trimestrales de restauración
mp.s.1	Protección del correo electrónico	No	Media - obligatoria	No aplica	No forma parte de la Base de Datos
mp.s.2	Protección de servicios y aplicaciones web	Sí	Media + R1/R2	Implantada	WAF, HTTPS, escaneos mensuales, pentest anual y bastionado de LMS, app móvil y portales.
mp.s.3	Protección de la navegación web	No	Media - obligatoria	No aplica	No aplica a Base de Datos
mp.s.4	Protección frente a denegación de servicio	Sí	D Media	Implantada	Protección AntiDDoS en CDN/cloud, reglas perimetrales y planes de escalado ante indisponibilidad.

5.4.2 Plataforma de Aprendizaje (Sistemas SaaS)

La plataforma de aprendizaje es un sistema de software que nos permite acceder a ciertas funciones, como puede ser el acceso a los contenidos educativos (apuntes, teoría, etc), seguimiento académico, comunicación, entre otras muchas funciones más.

Hemos elegido este sistema porque se trata de un sistema de alta criticidad, debido a que su funcionamiento esencial para la actividad educativa y una interrupción puede causar una paralización de clases, evaluaciones, etc.

INVENTARIO Y VALORACIÓN DE ACTIVOS

ID	Nombre del activo	Tipo	Confidenc.	Integrid.	Disponib.	Autenticid.	Trazabil.
INF-05	Datos personales de alumnos (LMS)	Información	Alta	Alta	Alta	Alta	Alta
INF-06	Datos personales de docentes y personal administrativo	Información	Alta	Alta	Alta	Alta	Alta
INF-07	Credenciales de acceso	Información	Alta	Alta	Alta	Alta	Alta
INF-08	Registro académicos y calificaciones	Información	Alta	Alta	Media	Alta	Alta
INF-09	Materiales y Recursos de aprendizaje	Información	Media	Alta	Alta	Media	Media
SW-03	Plataforma LMS	Software	Media	Alta	Alta	Alta	Media
INF-10	Historial de asistencia del alumnado	Información	Alta	Alta	Media	Alta	Alta
SW-04	Sistema de planificación horario y grupo	Software	Baja	Alta	Alta	Alta	Media

IDENTIFICACIÓN Y EVALUACIÓN DE AMENAZAS

Activo	Amenaza	Probabilidad (justificación)	Impacto (consecuencia)	Efecto (resultado, probab + impacto)	Tratamiento (tecnología. Normativa o personas)	Prioridad
INF-05	Acceso no autorizado y fuga de datos personales de menores	Media, los entornos educativos son objetivos frecuentes	El acceso no autorizado a datos personales puede generar sanciones de la RGPD	Venta o filtración de datos sensibles de menores	Tecnología (MFA, control de acceso cifrado)	2- Alta
INF-06	Fuga de información	Baja, es menos probable y poco	Datos laborales como personales quedan expuestos	Suplantación de identidad	Tecnología (Cifrado)	3- Media

		atractivo para los atacantes				
INF-07	Robo de credenciales o phishing	Alta, debido a que el phishing es muy frecuente	Accesos no autorizados a la cuenta, plataforma, etc	Fuga de datos y suplantación de identidad	Tecnología (MFA, bloqueo de Ips sospechosas)	1- Crítica
INF-08	Manipulación de calificaciones	Baja, poco probable que puedan acceder al registro de calificaciones	Falsificaciones de notas	Alteración del expediente académico	Normativa (Poder registrar y auditar acciones (logs))	2- Alta
INF-09	Perdida o alteración del contenido	Baja, debido a que los contenidos también los puedes encontrar en internet	No poder acceder a los contenidos además de la interrupción temporal de clases	Interrupción de clase y pérdida de recursos	Tecnología (Backups)	3- Media
SW-03	Caída del servicio	Media, depende del proveedor, actualizaciones o problemas de red	Dejaría sin acceso y además paraliza la actividad educativa	Interrupción del aprendizaje	Tecnología (Monitorización y redundancia)	2- Alta
INF-010	Alteración de registros	Media, porque es menos atractivo para el atacante	Afecta a la hora de calificar	Asistencia falsa	Normativa (Logs y control de accesos)	3- Media
SW-04	Error en la planificación	Baja, se debe a errores humanos	Desorganización de horarios, confusiones, etc	Interrupción del calendario y pérdida de clases programadas	Personas (Validación y revisión de horarios)	3- Media



DECLARACIÓN DE APLICABILIDAD (LMS)

Código	Control ENS	Aplica	Nivel / refuerzo	Estado	Justificación global / evidencia prevista
org.1	Política de seguridad	Sí	Media - obligatoria	Implantada	Política corporativa aprobada por Dirección. Define misión educativa, marco legal, roles, comité, documentación y riesgos derivados del tratamiento de datos personales.
org.2	Normativa de seguridad	Sí	Media - obligatoria	Implantada	Normas internas de uso aceptable, clasificación de la información, dispositivos móviles, teletrabajo, IA, correo y tratamiento de datos de menores.
org.3	Procedimientos de seguridad	Sí	Media - obligatoria	Implantada	Procedimientos comunes para operación, reporte de anomalías, copias, etiquetado, transmisión segura, gestión de cambios e incidentes en los 17 centros.
org.4	Proceso de autorización	Sí	Media - obligatoria	Implantada	Autorización formal para altas de usuarios, entrada de sistemas en producción, servicios cloud, soportes, comunicaciones y proveedores.
op.pl.1	Análisis de riesgos	Sí	Media + R1	Implantada	Análisis semiformal MAGERIT con activos, amenazas, salvaguardas y riesgo residual. Revisión anual y ante cambios relevantes.
op.pl.2	Arquitectura de seguridad	Sí	Media + R1	Implantada	Arquitectura documentada con líneas de defensa: IAM, segmentación, NGFW, DMZ, SIEM, EDR, cloud híbrido y controles de datos sensibles.
op.pl.3	Adquisición de nuevos componentes	Sí	Media - obligatoria	Implantada	Proceso de aprobación TIC/RSI antes de adquirir LMS, servicios cloud, aplicaciones educativas o componentes de seguridad.
op.pl.4	Dimensionamiento / gestión de la capacidad	Sí	Dimensión D - Media + R1	Implantada	Capacidad monitorizada para LMS, ERP, WiFi, M365 y cloud. Previsión de demanda en exámenes, matrículas e inicio de curso.
op.pl.5	Componentes certificados	Sí	Media - obligatoria	Parcial	Preferencia por productos y servicios cualificados en CPSTIC/CCN o con certificaciones reconocidas. Plan de madurez para proveedores cloud y seguridad.
op.acc.1	Identificación	Sí	T/A Media + R1	Implantada	Identificadores únicos y nominales en IAM corporativo; separación de perfiles alumno, docente, PAS, TIC y administrador.
op.acc.2	Requisitos de acceso	Sí	C/I/T/A Media	Implantada	Accesos protegidos por mínimo privilegio, necesidad de conocer y matrices de permisos por perfil profesional y servicio.
op.acc.3	Segregación de funciones y tareas	Sí	C/I/T/A Media	Implantada	Separación entre RSI, responsable del sistema, operación, auditoría, desarrollo y aprobación de cambios críticos.
op.acc.4	Gestión de derechos de acceso	Sí	C/I/T/A Media	Implantada	Altas, modificaciones y bajas mediante IAM; revisión semestral; deshabilitación de accesos tras baja o cambio de rol.
op.acc.5	Autenticación usuarios externos	Sí	C/I/T/A Media + MFA/registro	Implantada	Familias, alumnado universitario, proveedores y terceros acceden con MFA, registro de accesos y condiciones específicas según perfil.
op.acc.6	Autenticación usuarios internos	Sí	C/I/T/A Media + MFA	Implantada	MFA para personal, TIC y administradores; bloqueo de sesión, contraseñas robustas y controles adicionales para privilegios elevados.
op.exp.1	Inventario de activos	Sí	Media - obligatoria	Implantada	CMDb corporativa con activos de información, software, hardware, redes, cloud, personal clave e instalaciones.
op.exp.2	Configuración de seguridad	Sí	Media - obligatoria	Implantada	Bastionado de servidores, endpoints, M365, LMS, firewalls y servicios cloud mediante guías CCN-STIC/CIS.
op.exp.3	Gestión de configuración de seguridad	Sí	Media + R1	Implantada	Repositorio de configuraciones, control de versiones, revisión de cambios y validación previa a producción.
op.exp.4	Mantenimiento y actualizaciones de seguridad	Sí	Media + R1	Implantada	Parches críticos en <=72h, altos en <=15 días, medios en <=60 días. Priorización por exposición y criticidad.
op.exp.5	Gestión de cambios	Sí	Media - obligatoria	Implantada	CAB corporativo, pruebas en preproducción y aprobación formal para cambios en LMS, ERP, IAM, red y cloud.
op.exp.6	Protección frente a código dañino	Sí	Media + R1/R2	Implantada	EDR corporativo, antimalware, bloqueo de macros, sandboxing de adjuntos y monitorización
op.exp.7	Gestión de incidentes	Sí	Media + R1/R2	Implantada	Procedimiento P1-P4, escalado a RSI/DPD/Dirección, registro de evidencias y notificación regulatoria cuando proceda.
op.exp.8	Registro de la actividad	Sí	T Media + refuerzos	Implantada	Logs centralizados en SIEM: IAM, LMS, VPN, firewall, EDR, servidores, BBDD y servicios cloud. Retención proporcional.
op.exp.9	Registro de gestión de incidentes	Sí	Media - obligatoria	Implantada	Ticketing integrado. Registro de triaje, contención, análisis, erradicación, recuperación y lecciones aprendidas.
op.exp.10	Protección de claves criptográficas	Sí	Media + R1	Implantada	Custodia de claves en almacenes seguros/HSM cloud cuando aplique; rotación, separación de funciones y acceso restringido.
op.ext.1	Contratación y acuerdos de nivel de servicio	Sí	Media - obligatoria	Implantada	Contratos con cláusulas de seguridad, confidencialidad, RGPD, auditoría, notificación de incidentes y devolución/destrucción de datos.
op.ext.2	Gestión diaria de proveedores	Sí	Media - obligatoria	Implantada	Revisión periódica de proveedores críticos: LMS, cloud, M365, conectividad y soporte externo.
op.ext.3	Protección de la cadena de suministro	Sí	Adicional por riesgo	Parcial	Para proveedores cloud/LMS y subcontratistas. Medida aplicada por dependencia de terceros
op.ext.4	Interconexión de sistemas	Sí	Media - obligatoria	Implantada	Control de integraciones entre sedes, cloud, LMS, ERP, M365, VPN y redes de invitados. Revisión de puntos de interconexión.
op.nub.1	Protección de servicios en la nube	Sí	Media + R1	Implantada	Configuración segura de AWS/Azure/M365, cifrado, IAM cloud, registro de actividad, revisión de permisos y respaldo contractual.
op.cont.1	Análisis de impacto	Sí	Dimensión D - Media	Implantada	BIA corporativo para LMS, ERP, correo, WiFi, Internet, sistemas y procesos académicos críticos.
op.cont.2	Plan de continuidad	Sí	Adicional por riesgo	Implantada	PCN aplicado, aunque no siempre sea exigible en Media, por continuidad docente, evaluación, matrícula y comunicación familias.
op.cont.3	Pruebas periódicas	Sí	Adicional por riesgo	Implantada	Simulacro anual y pruebas trimestrales de restauración. Participan TIC central y responsables TIC locales.
op.cont.4	Medios alternativos	Sí	Adicional por riesgo	Implantada	Conectividad redundante, modo degradado LMS, copias offsite, contingencia 4G/5G y operación alternativa por centro.

Código	Control ENS	Aplica	Nivel / refuerzo	Estado	Justificación global / evidencia prevista
op.mon.1	Detección de intrusión	Sí	Media + R1	Implantada	Reglas SIEM orientadas a ransomware, phishing, DDoS y explotación del LMS.
op.mon.2	Sistema de métricas	Sí	Media + R1/R2	Implantada	Cuadro de mando semestral: parches, incidentes, MFA, formación, vulnerabilidades, backups, proveedores y cobertura SIEM.
op.mon.3	Vigilancia	Sí	Media + R1/R2	Implantada	Monitorización continua por, threat intelligence, detección de anomalías y revisión periódica de vulnerabilidades.
mp.if.1	Áreas separadas y control de acceso	No	Media - obligatoria	No aplica	No aplica, debido a que la infraestructura de datos se encuentra en los centros de datos del proveedor cloud.
mp.if.2	Identificación de las personas	No	Media - obligatoria	No aplica	No aplica, debido a que el control de acceso a los centros de datos lo gestiona el proveedor
mp.if.3	Acondicionamiento de locales	No	Media - obligatoria	No aplica	No aplica, debido a que no existen locales para alojar el LMS, más bien el proveedor gestiona la climatización y condiciones de este
mp.if.4	Energía eléctrica	No	D Media + R1	No aplica	No aplica, ya que todo el tema eléctrico y los sistemas SAI son responsabilidad del proveedor cloud
mp.if.5	Protección frente a incendios	No	Media - obligatoria	No aplica	No aplica, la protección contra incendios de la base de datos son responsabilidad del proveedor cloud
mp.if.6	Protección frente a inundaciones	No	D Media	No aplica	No aplica, la protección contra inundaciones de la base de datos son responsabilidad del proveedor cloud
mp.if.7	Registro de entrada/salida de equipamiento	No	Media - obligatoria	No aplica	No aplica, no hay equipamiento físico propio para gestionar el LMS
mp.per.1	Caracterización del puesto de trabajo	Sí	Media - obligatoria	Implantada	Perfiles de puesto con requisitos de seguridad, confidencialidad y acceso según función docente, PAS, TIC o directiva.
mp.per.2	Deberes y obligaciones	Sí	Media + R1	Implantada	AUP, confidencialidad, obligaciones RGPD, deber de custodia de credenciales y régimen disciplinario.
mp.per.3	Concienciación	Sí	Media - obligatoria	Implantada	Formación anual, simulaciones de phishing y comunicación de buenas prácticas a todo el personal.
mp.per.4	Formación	Sí	Media - obligatoria	Implantada	Formación específica para TIC en ENS, gestión de incidentes, bastionado, forense básica y protección de menores.
mp.eq.1	Puesto de trabajo despejado	No	Media + R1	No aplica	No aplica, los puestos de trabajo personal no forman parte del alcance del sistema SaaS evaluado
mp.eq.2	Bloqueo de puesto de trabajo	No	A Media	No aplica	No aplica, el bloqueo de puesto de trabajo no está en el alcance de este sistema
mp.eq.3	Protección de dispositivos portátiles	No	Media - obligatoria	No aplica	No aplica, no está en el alcance del sistema
mp.eq.4	Otros dispositivos conectados ala red	No	C Media + R1	No aplica	No aplica, no está relacionado con la plataforma LMS
mp.com.1	Perímetro seguro	Sí	Media - obligatoria	Implantada	NGFW, DMZ, reglas de filtrado, proxy, WAF y revisión de exposición externa.
mp.com.2	Protección de la confidencialidad	Sí	C Media + R1	Implantada	TLS 1.3, VPN, cifrado de enlaces SD-WAN, protección de datos de menores
mp.com.3	Protección de integridad y autenticidad	Sí	I/A Media + R1/R2	Implantada	Certificados, firma electrónica, control de integridad, hash de evidencias y validación de comunicaciones.
mp.com.4	Separación de flujos de información en red	Sí	Media + R1/R2/R3	Implantada	VLAN y políticas separadas para alumnos, docentes/PAS, servidores, gestión, invitados, IoT/VR y proveedores.
mp.si.1	Marcado de soportes	No	C Media	No aplica	No aplica, porque no se utilizan soportes físicos para el almacenamiento de los sistemas de información
mp.si.2	Criptografía	Sí	C/I Media	Implantada	AES-256 en reposo, TLS 1.3 en tránsito, claves gestionadas y políticas de uso criptográfico.
mp.si.3	Custodia	Sí	Media - obligatoria	Implantada	Custodia de soportes y copias en ubicaciones protegidas, con acceso restringido y trazabilidad.
mp.si.4	Transporte	No	Media - obligatoria	No aplica	No aplica, no se transportan soportes físicos con información del LMS, todo el intercambio es digital y cifrado
mp.si.5	Borrado y destrucción	Sí	C Media + R1	Implantada	Borrado seguro lógico y destrucción certificada de soportes al final de vida útil.
mp.sw.1	Desarrollo de aplicaciones	Sí	Media + R1/R2/R3/R4	Implantada	SSDLC: revisión de código, SAST/DAST, gestión de secretos, segregación de entornos y prohibición de datos reales en pruebas.
mp.sw.2	Aceptación y puesta en servicio	Sí	Media + R1	Implantada	Pruebas funcionales y de seguridad, aprobación de RSI y responsable del servicio antes de producción.
mp.info.1	Datos personales	Sí	Media - obligatoria	Implantada	RAT, EIPD para menores, minimización, base jurídica, derechos y medidas RGPD/LOPDGDD.
mp.info.2	Calificación de la información	Sí	C Media	Implantada	Clasificación corporativa de información y reglas de tratamiento por nivel.
mp.info.3	Firma electrónica	Sí	I/A Media + refuerzos	Parcial	Firma electrónica en documentos académicos, autorizaciones, actas y evidencias de auditoría relevantes.
mp.info.4	Sellos de tiempo	Sí	Adicional por riesgo	Planificada	Sellado temporal para evidencias críticas, registros de auditoría y documentos académicos con efectos probatorios.
mp.info.5	Limpieza de documentos	Sí	C Media	Implantada	Revisión de metadatos, anonimización cuando proceda y control de documentos antes de publicación o envío externo.
mp.info.6	Copias de seguridad	Sí	D Media + R1	Implantada	Copias cifradas, pruebas trimestrales de restauración
mp.s.1	Protección del correo electrónico	Sí	Media - obligatoria	Implantada	Antiphishing, sandboxing, formación y reporte rápido
mp.s.2	Protección de servicios y aplicaciones web	Sí	Media + R1/R2	Implantada	WAF, HTTPS, escaneos mensuales, pentest anual y bastionado de LMS, app móvil y portales.
mp.s.3	Protección de la navegación web	Sí	Media - obligatoria	Implantada	Proxy, filtrado DNS/URL, inspección de malware y bloqueo de categorías de riesgo.
mp.s.4	Protección frente a denegación de servicio	Sí	D Media	Implantada	Protección AntiDDoS en CDN/cloud, reglas perimetrales y planes de escalado ante indisponibilidad.

5.4.3 Infraestructura de red

La infraestructura de red es el conjunto de elementos físicos y lógicos que permiten la comunicación entre los dispositivos de nuestra empresa.

Hemos elegido este sistema porque soporta todos los servicios, afecta de forma directa a la disponibilidad, permite la trazabilidad y centraliza la seguridad.

INVENTARIO Y VALORACIÓN DE ACTIVOS

ID	Nombre del activo	Tipo	Confidenc.	Integrid.	Disponib.	Autenticid.	Trazabil.
SW-05	Switches de acceso	Hardware	Media	Alta	Alta	Alta	Media
WiFi-01	Infraestructura WiFi	Software	Alta	Alta	Alta	Alta	Media
Fi-01	Firewall	Software	Alta	Alta	Alta	Alta	Media
Ro-01	Router principal	Hardware	Media	Alta	Media	Alta	Media
Ba-03	Back-ups de configuraciones de red	Información	Alta	Alta	Alta	Media	Alta
Ca-02	Cableado estructurado (UTP/Fibra)	Infraestructura	Baja	Alta	Alta	Baja	Baja
DHCP-01	Servidor DHCP	Software	Baja	Alta	Alta	Media	Media
VPN-01	VPN corporativo	Software	Alta	Alta	Alta	Media	Alta
LOG-01	Logs	Información	Alta	Alta	Alta	Alta	Alta

IDENTIFICACIÓN Y EVALUACIÓN DE AMENAZAS

Activo	Amenaza	Probabilidad (justificación)	Impacto (consecuencia)	Efecto (resultado, probab + impacto)	Tratamiento (tecnología. Normativa o personas)	Prioridad
SW-05	Acceso no autorizado a puertos (intrusión física/lógica)	Media, entornos educativos con acceso físico frecuente	Compromiso de red interna	Robo de información	Normativa (control acceso), Personas (concienciación)	2- Alta
WiFi-01	Ataque de desautenticación	Media, poco probable que suceda este ataque en redes 5g ya que los medios convencionales	La red queda inhabilitada	Los usuarios no pueden utilizar la red	Tecnología (certificado de red) Normativa (Mejores políticas de acceso) Persona (formación y concienciación en redes)	2- Alta

		(ESP32) no tiene tanta potencia				
Fi-01	DDoS	Alta, los atacantes en un ataque DDoS suelen saturar el Firewall para que nadie pueda salir ni entrar, ya que el Firewall actúa como una puerta	Caída de servicios	La red queda inaccesible	Tecnología (protección DDoS)	2 - Alta
Ro-01	Configuración incorrecta	Media, es posible que alguien no haya configurado el Router con los protocolos necesarios dejándolo vulnerable	Fallo en rutas	Interrupción de red	Normativa (asegurar la configuración de los Routers) Personas (formación y concienciación en redes)	2- Alta
Ba-03	Pérdida de Backups	Baja, no suele ocurrir que se pierdan los backups ya que contienen información sensible	Imposibilidad de verificar la integridad de los datos e imposibilidad de recuperar los datos	Pérdida de datos	Tecnológica	1- Crítica
Ca-02	Corte físico de los cables	Media, es posible que haya un técnico o una obra corte los cables al no conocer donde están estos	Pérdida de conectividad	Zona sin red	Normativa (protección física)	3- Media
DHCP-01	Caída de servicio	Media, es posible que haya un error con el DHCP y se caiga el servicio	No hay asignación de IPs en los equipos	Usuarios sin red	Tecnológica (Alta disponibilidad)	2- Alta
VPN-01	Robo de credenciales	Media, es posible que las credenciales usadas para trabajar de forma	Acceso remoto no autorizado	Brecha de seguridad	Tecnológica (MFA) Normativa (No compartir claves) Personas (Formación y concienciación en seguridad)	1- Crítica
LOG-01	Manipulación de Logs	Media, es posible que al hacer un ataque intenten manipular los logs para que se pierda la trazabilidad	Pérdida de trazabilidad	Dificulta al detectar incidentes y de dónde han accedido	Tecnológica (SIEM, integridad)	1- Crítica

DECLARACIÓN DE APLICABILIDAD (RED)

Código	Control ENS	Aplica	Nivel / refuerzo	Estado	Justificación global / evidencia prevista
org.1	Política de seguridad	Sí	Media - obligatoria	Implantada	Política corporativa aprobada por Dirección. Define misión educativa, marco legal, roles, comité, documentación y riesgos derivados del tratamiento de datos personales.
org.2	Normativa de seguridad	Sí	Media - obligatoria	Implantada	Normas internas de uso aceptable, clasificación de la información, dispositivos móviles, teletrabajo, IA, correo y tratamiento de datos de menores.
org.3	Procedimientos de seguridad	Sí	Media - obligatoria	Implantada	Procedimientos comunes para operación, reporte de anomalías, copias, etiquetado, transmisión segura, gestión de cambios e incidentes en los 17 centros.
org.4	Proceso de autorización	Sí	Media - obligatoria	Implantada	Autorización formal para altas de usuarios, entrada de sistemas en producción, servicios cloud, soportes, comunicaciones y proveedores.
op.pl.1	Análisis de riesgos	Sí	Media + R1	Implantada	Análisis semiformal MAGERIT con activos, amenazas, salvaguardas y riesgo residual. Revisión anual y ante cambios relevantes.
op.pl.2	Arquitectura de seguridad	Sí	Media + R1	Implantada	Arquitectura documentada con líneas de defensa: IAM, segmentación, NGFW, DMZ, SIEM, EDR, cloud híbrido y controles de datos sensibles.
op.pl.3	Adquisición de nuevos componentes	Sí	Media - obligatoria	Implantada	Proceso de aprobación TIC/RSI antes de adquirir LMS, servicios cloud, aplicaciones educativas o componentes de seguridad.
op.pl.4	Dimensionamiento / gestión de la capacidad	Sí	Dimensión D - Media + R1	Implantada	Capacidad monitorizada para LMS, ERP, WiFi, M365 y cloud. Previsión de demanda en exámenes, matrículas e inicio de curso.
op.pl.5	Componentes certificados	Sí	Media - obligatoria	Parcial	Preferencia por productos y servicios cualificados en CPSTIC/CCN o con certificaciones reconocidas. Plan de madurez para proveedores cloud y seguridad.
op.acc.1	Identificación	Sí	T/A Media + R1	Implantada	Identificadores únicos y nominales en IAM corporativo; separación de perfiles alumno, docente, PAS, TIC y administrador.
op.acc.2	Requisitos de acceso	Sí	C/I/T/A Media	Implantada	Accesos protegidos por mínimo privilegio, necesidad de conocer y matrices de permisos por perfil profesional y servicio.
op.acc.3	Segregación de funciones y tareas	Sí	C/I/T/A Media	Implantada	Separación entre RSI, responsable del sistema, operación, auditoría, desarrollo y aprobación de cambios críticos.
op.acc.4	Gestión de derechos de acceso	Sí	C/I/T/A Media	Implantada	Altas, modificaciones y bajas mediante IAM; revisión semestral; deshabilitación de accesos tras baja o cambio de rol.
op.acc.5	Autenticación usuarios externos	Sí	C/I/T/A Media MFA/registro +	Implantada	Familias, alumnado universitario, proveedores y terceros acceden con MFA, registro de accesos y condiciones específicas según perfil.
op.acc.6	Autenticación usuarios internos	Sí	C/I/T/A Media + MFA	Implantada	MFA para personal, TIC y administradores; bloqueo de sesión, contraseñas robustas y controles adicionales para privilegios elevados.
op.exp.1	Inventario de activos	Sí	Media - obligatoria	Implantada	CMDB corporativa con activos de información, software, hardware, redes, cloud, personal clave e instalaciones.
op.exp.2	Configuración de seguridad	Sí	Media - obligatoria	Implantada	Bastionado de servidores, endpoints, M365, LMS, firewalls y servicios cloud mediante guías CCN-STIC/CIS.
op.exp.3	Gestión de configuración de seguridad	Sí	Media + R1	Implantada	Repositorio de configuraciones, control de versiones, revisión de cambios y validación previa a producción.
op.exp.4	Mantenimiento y actualizaciones de seguridad	Sí	Media + R1	Implantada	Parches críticos en <=72h, altos en <=15 días, medios en <=60 días. Priorización por exposición y criticidad.
op.exp.5	Gestión de cambios	Sí	Media - obligatoria	Implantada	CAB corporativo, pruebas en preproducción y aprobación formal para cambios en LMS, ERP, IAM, red y cloud.
op.exp.6	Protección frente a código dañino	No	Media + R1/R2	No aplica	Equipos de red no ejecutan software convencional.
op.exp.7	Gestión de incidentes	Sí	Media + R1/R2	Implantada	Procedimiento P1-P4, escalado a RSI/DPD/Dirección, registro de evidencias y notificación regulatoria cuando proceda.
op.exp.8	Registro de la actividad	Sí	T Media + refuerzos	Implantada	Logs centralizados en SIEM: IAM, LMS, VPN, firewall, EDR, servidores, BBDD y servicios cloud. Retención proporcional.
op.exp.9	Registro de gestión de incidentes	Sí	Media - obligatoria	Implantada	Ticketing integrad. Registro de triaje, contención, análisis, erradicación, recuperación y lecciones aprendidas.
op.exp.10	Protección de claves criptográficas	Sí	Media + R1	Implantada	Custodia de claves en almacenes seguros/HSM cloud cuando aplique; rotación, separación de funciones y acceso restringido.
op.ext.1	Contratación y acuerdos de nivel de servicio	Sí	Media - obligatoria	Implantada	Contratos con cláusulas de seguridad, confidencialidad, RGPD, auditoría, notificación de incidentes y devolución/destrucción de datos.
op.ext.2	Gestión diaria de proveedores	Sí	Media - obligatoria	Implantada	Revisión periódica de proveedores críticos: LMS, cloud, M365, conectividad y soporte externo.
op.ext.3	Protección de la cadena de suministro	Sí	Adicional por riesgo	Parcial	Para proveedores cloud/LMS y subcontratistas. Medida aplicada por dependencia de terceros
op.ext.4	Interconexión de sistemas	Sí	Media - obligatoria	Implantada	Control de integraciones entre sedes, cloud, LMS, ERP, M365, VPN y redes de invitados. Revisión de puntos de interconexión.
op.nub.1	Protección de servicios en la nube	Sí	Media + R1	Implantada	Configuración segura de AWS/Azure/M365, cifrado, IAM cloud, registro de actividad, revisión de permisos y respaldo contractual.
op.cont.1	Análisis de impacto	Sí	Dimensión D - Media	Implantada	BIA corporativo para LMS, ERP, correo, WiFi, Internet, sistemas y procesos académicos críticos.
op.cont.2	Plan de continuidad	Sí	Adicional por riesgo	Implantada	PCN aplicado, aunque no siempre sea exigible en Media, por continuidad docente, evaluación, matrícula y comunicación familias.
op.cont.3	Pruebas periódicas	Sí	Adicional por riesgo	Implantada	Simulacro anual y pruebas trimestrales de restauración. Participan TIC central y responsables TIC locales.
op.cont.4	Medios alternativos	Sí	Adicional por riesgo	Implantada	Conectividad redundante, modo degradado LMS, copias offsite, contingencia 4G/5G y operación alternativa por centro.
op.mon.1	Detección de intrusión	Sí	Media + R1	Implantada	Reglas SIEM orientadas a ransomware, phishing, DDoS y explotación del LMS.
op.mon.2	Sistema de métricas	Sí	Media + R1/R2	Implantada	Cuadro de mando semestral: parches, incidentes, MFA, formación, vulnerabilidades, backups, proveedores y cobertura SIEM.

Código	Control ENS	Aplica	Nivel / refuerzo	Estado	Justificación global / evidencia prevista
op.mon.3	Vigilancia	Sí	Media + R1/R2	Implantada	Monitorización continua por, threat intelligence, detección de anomalías y revisión periódica de vulnerabilidades.
mp.if.1	Áreas separadas y control de acceso	Sí	Media - obligatoria	Implantada	Zonas controladas y acceso restringido al personal autorizado y registro de entradas.
mp.if.2	Identificación de las personas	Sí	Media - obligatoria	Implantada	Tarjeta corporativa, control de visitantes y verificación de identidad para acceso a zonas sensibles.
mp.if.3	Acondicionamiento de locales	Sí	Media - obligatoria	Implantada	Climatización, sensores ambientales, control de humedad, detección de humo y mantenimiento preventivo en instalaciones
mp.if.4	Energía eléctrica	Sí	D Media + R1	Implantada	SAI, grupo electrógeno y redundancia eléctrica para sedes principales.
mp.if.5	Protección frente a incendios	Sí	Media - obligatoria	Implantada	Detección y extinción automática y procedimientos de evacuación y revisión periódica.
mp.if.6	Protección frente a inundaciones	Sí	D Media	Implantada	Sensores de agua, ubicación elevada de equipos, revisión de riesgos físicos y plan de contingencia.
mp.if.7	Registro de entrada/salida de equipamiento	Sí	Media - obligatoria	Implantada	Registro de salida, entrada, reparación y baja de equipos TIC, soportes y dispositivos móviles corporativos.
mp.per.1	Caracterización del puesto de trabajo	Sí	Media - obligatoria	Implantada	Perfiles de puesto con requisitos de seguridad, confidencialidad y acceso según función docente, PAS, TIC o directiva.
mp.per.2	Deberes y obligaciones	Sí	Media + R1	Implantada	AUP, confidencialidad, obligaciones RGPD, deber de custodia de credenciales y régimen disciplinario.
mp.per.3	Concienciación	Sí	Media - obligatoria	Implantada	Formación anual, simulaciones de phishing y comunicación de buenas prácticas a todo el personal.
mp.per.4	Formación	Sí	Media - obligatoria	Implantada	Formación específica para TIC en ENS, gestión de incidentes, bastionado, forense básica y protección de menores.
mp.eq.1	Puesto de trabajo despejado	No	Media + R1	No aplica	No aplica directamente a infraestructura de red (orientado a usuarios finales).
mp.eq.2	Bloqueo de puesto de trabajo	No	A Media	No aplica	No forma parte directa de la infraestructura de red.
mp.eq.3	Protección de dispositivos portátiles	No	Media - obligatoria	No aplica	No forma parte directa de la infraestructura de red.
mp.eq.4	Otros dispositivos conectados ala red	Sí	C Media + R1	Implantada	Segmentación IoT/VR/AR, inventario de dispositivos y autorización previa antes de conexión a red corporativa.
mp.com.1	Perímetro seguro	Sí	Media - obligatoria	Implantada	NGFW, DMZ, reglas de filtrado, proxy, WAF y revisión de exposición externa.
mp.com.2	Protección de la confidencialidad	Sí	C Media + R1	Implantada	TLS 1.3, VPN, cifrado de enlaces SD-WAN, protección de datos de menores
mp.com.3	Protección de integridad y autenticidad	Sí	I/A Media + R1/R2	Implantada	Certificados, firma electrónica, control de integridad, hash de evidencias y validación de comunicaciones.
mp.com.4	Separación de flujos de información en red	Sí	Media + R1/R2/R3	Implantada	VLAN y políticas separadas para alumnos, docentes/PAS, servidores, gestión, invitados, IoT/VR y proveedores.
mp.si.1	Marcado de soportes	No	C Media	No aplica	No relevante para infraestructura de red.
mp.si.2	Criptografía	Sí	C/I Media	Implantada	AES-256 en reposo, TLS 1.3 en tránsito, claves gestionadas y políticas de uso criptográfico.
mp.si.3	Custodia	No	Media - obligatoria	No aplica	Aplicable a soportes físicos, no a red directamente.
mp.si.4	Transporte	No	Media - obligatoria	No aplica	Aplicable a soportes físicos, no a red directamente.
mp.si.5	Borrado y destrucción	No	C Media + R1	No aplica	No aplica de forma directa a la red.
mp.sw.1	Desarrollo de aplicaciones	No	Media + R1/R2/R3/R4	No aplica	No forma parte de la infraestructura red.
mp.sw.2	Aceptación y puesta en servicio	Sí	Media + R1	Implantada	Pruebas funcionales y de seguridad, aprobación de RSI y responsable del servicio antes de producción.
mp.info.1	Datos personales	Sí	Media - obligatoria	Implantada	RAT, EIPD para menores, minimización, base jurídica, derechos y medidas RGPD/LOPDGDD.
mp.info.2	Calificación de la información	Sí	C Media	Implantada	Clasificación corporativa de información y reglas de tratamiento por nivel.
mp.info.3	Firma electrónica	No	I/A Media + refuerzos	No aplica	No tiene función directa en la infraestructura de red.
mp.info.4	Sellos de tiempo	No	Adicional por riesgo	No aplica	No relacionado con la infraestructura de red.
mp.info.5	Limpieza de documentos	No	C Media	No aplica	La red actúa únicamente como medio de transporte de la información, sin intervenir en su edición o tratamiento.
mp.info.6	Copias de seguridad	Sí	D Media + R1	Implantada	Copias cifradas, pruebas trimestrales de restauración
mp.s.1	Protección del correo electrónico	No	Media - obligatoria	No aplica	Servicio de aplicación, no infraestructura de red.
mp.s.2	Protección de servicios y aplicaciones web	Sí	Media + R1/R2	Implantada	WAF, HTTPS, escaneos mensuales, pentest anual y bastionado de LMS, app móvil y portales.
mp.s.3	Protección de la navegación web	Sí	Media - obligatoria	Implantada	Proxy, filtrado DNS/URL, inspección de malware y bloqueo de categorías de riesgo.
mp.s.4	Protección frente a denegación de servicio	Sí	D Media	Implantada	Protección AntiDDoS en CDN/cloud, reglas perimetrales y planes de escalado ante indisponibilidad.

5.4.4 App móvil:

La aplicación móvil es un sistema el cual consiste en componentes software y servicios que permiten a los usuarios acceder a funcionalidades que les ayudarán con su formación como un calendario, fechas importantes, noticias, eventos desde sus dispositivos

Hemos elegido este sistema porque gestiona datos de usuarios, expone servicios, depende de la disponibilidad de la infraestructura y concentra aspectos clave de seguridad como el control de accesos, la trazabilidad y la protección de la información de los alumnos y docentes.

INVENTARIO Y VALORACIÓN DE ACTIVOS

ID	Nombre del activo	Tipo	Confidenc.	Integrid.	Disponib.	Autenticid.	Trazabil.
AM-1	Código fuente (frontend y backend)	software	Alta	Alta	Alta	Alta	Media
AM-2	API	software	Alta	Alta	Alta	Alta	Alta
AM-3	Librerías	software	Alta	Alta	Media	Alta	Media
AM-4	Sistema operativo	software	Alta	Media	Alta	Alta	Alta
AM-5	Datos de usuarios	Información	Alta	Alta	Alta	Alta	Media
AM-6	Logs	Información	Media	Alta	Media	Media	Alta
AM-7	Alertas de seguridad	Información	Media	Alta	Alta	Alta	Media
AM-8	Servidores	Hardware	Media	Alta	Alta	Media	Media
AM-9	Redes	Hardware	Media	Alta	Alta	Media	Baja

IDENTIFICACIÓN Y EVALUACIÓN DE AMENAZAS

Activo	Amenaza	Probabilidad (justificación)	Impacto (consecuencia)	Efecto (resultado, probab + impacto)	Tratamiento (tecnología. Normativa o personas)	Prioridad
AM-1	Acceso no autorizado al repositorio (robo o fuga de código)	Media, se puede dar a nivel físico por algún empleado o puede ser virtual, es posible que pase ya que hay un constante acceso a la app y hay mucho movimiento de datos.	Códigos maliciosos ocultos, malwares, puertas traseras, nuevas vulnerabilidades	Fallos en el sistema, ataques continuos.	Normativo (Control de accesos), Tecnología (repositorios privados)	1- Alta
AM-2	Inyección SQL	Media, es complicado que se puede llevar a cabo este ataque ya que hay muchas medidas, pero siempre existen vulnerabilidades.	Compromiso total del sistema	Robo o manipulación de datos sensibles, destrucción de datos, bypass	Tecnología (Validación de inputs, hacer uso de WAF)	2- Alta

				de autenticación		
AM-3	Librerías maliciosas	Alta, una librería puede verse normal y lícita, aunque un pequeño cambio puede significar que la librería sea maliciosa	puertas traseras y fallos	Acceso en todo momento al sistema.	Tecnología (Actualizaciones) normativo (Auditorías)	2- Alta
AM-4	Fallo en la detección de vulnerabilidades	Alta, Aunque hay constantes actualizaciones muchas con el fin de tapar y arreglar vulnerabilidades para que no sean usadas, siempre habrá alguna vulnerabilidad.	No hay control del sistema	Los activos y la información se pueden manipular o robar.	Tecnología (Parches y actualizaciones)	2- Alta
AM-5	Phishing	Alto, el factor humano es importante ya que el ataque tiene éxito o no depende de la persona.	Pérdida de reputación y problemas legales	Suplantación de identidad, estafa, robo de datos personales.	Tecnología (Cifrado de datos) personas (formación del personal)	3- Media
AM-6	Manipulación de logs	Alto, es posible modificar logs, ya que se hacen auditorías y se lleva registro de estos lo que hace que haya disponibilidad continua	Perdida de evidencias y se pierde trazabilidad.	Borrar el rastro de cualquier ciber ataque al sistema.	Tecnología (logs inmutables, SIEM) normativa (auditorías)	3- Media
AM-7	Generar alertas falsas	Alta, todos pueden iniciar sesión y forzar la alerta.	Intentos de inicios de sesión sospechosos o ataques sin detectar	Suplantación de identidad	Tecnología (Monitoreo continuo, MFA)	3- Media
AM-8	Ataque DDoS	Media, hay muchas medidas para prevenir la alta conexión de usuarios simultáneamente, pero se conectan muchos usuarios a al mismo tiempo	Caída de los servidores, no hay servicio	Dejar inútil y fuera de uso todo el sistema.	Tecnología (Balanceadores, limpieza de tráfico)	2- Alta
AM-9	Intercepción del tráfico (Man in the Middle)	Media, puede haber un problema de comunicación entre redes.	Datos privados y confidenciales comprometidos	Tráfico de información sensible.	Tecnología (Redes seguras, VPN, MFA)	1- Alta



DECLARACIÓN DE APLICABILIDAD (App móvil)

Código	Control ENS	Aplica	Nivel / refuerzo	Estado	Justificación global / evidencia prevista
org.1	Política de seguridad	Sí	Media - obligatoria	Implantada	Política corporativa aprobada por Dirección. Define misión educativa, marco legal, roles, comité, documentación y riesgos derivados del tratamiento de datos personales.
org.2	Normativa de seguridad	Sí	Media - obligatoria	Implantada	Normas internas de uso aceptable, clasificación de la información, dispositivos móviles, teletrabajo, IA, correo y tratamiento de datos de menores.
org.3	Procedimientos de seguridad	Sí	Media - obligatoria	Implantada	Procedimientos comunes para operación, reporte de anomalías, copias, etiquetado, transmisión segura, gestión de cambios e incidentes en los 17 centros.
org.4	Proceso de autorización	Sí	Media - obligatoria	Implantada	Autorización formal para altas de usuarios, entrada de sistemas en producción, servicios cloud, soportes, comunicaciones y proveedores.
op.pl.1	Análisis de riesgos	Sí	Media + R1	Implantada	Análisis semiformal MAGERIT con activos, amenazas, salvaguardas y riesgo residual. Revisión anual y ante cambios relevantes.
op.pl.2	Arquitectura de seguridad	Sí	Media + R1	Implantada	Arquitectura documentada con líneas de defensa: IAM, segmentación, NGFW, DMZ, SIEM, EDR, cloud híbrido y controles de datos sensibles.
op.pl.3	Adquisición de nuevos componentes	Sí	Media - obligatoria	Implantada	Proceso de aprobación TIC/RSI antes de adquirir LMS, servicios cloud, aplicaciones educativas o componentes de seguridad.
op.pl.4	Dimensionamiento / gestión de la capacidad	Sí	Dimensión D - Media + R1	Implantada	Capacidad monitorizada para LMS, ERP, WiFi, M365 y cloud. Previsión de demanda en exámenes, matrículas e inicio de curso.
op.pl.5	Componentes certificados	Sí	Media - obligatoria	Parcial	Preferencia por productos y servicios cualificados en CPSTIC/CCN o con certificaciones reconocidas. Plan de madurez para proveedores cloud y seguridad.
op.acc.1	Identificación	Sí	T/A Media + R1	Implantada	Identificadores únicos y nominales en IAM corporativo; separación de perfiles alumno, docente, PAS, TIC y administrador.
op.acc.2	Requisitos de acceso	Sí	C/I/T/A Media	Implantada	Accesos protegidos por mínimo privilegio, necesidad de conocer y matrices de permisos por perfil profesional y servicio.
op.acc.3	Segregación de funciones y tareas	Sí	C/I/T/A Media	Implantada	Separación entre RSI, responsable del sistema, operación, auditoría, desarrollo y aprobación de cambios críticos.
op.acc.4	Gestión de derechos de acceso	Sí	C/I/T/A Media	Implantada	Altas, modificaciones y bajas mediante IAM; revisión semestral; deshabilitación de accesos tras baja o cambio de rol.
op.acc.5	Autenticación usuarios externos	Sí	C/I/T/A Media + MFA/registro	Implantada	Familias, alumnado universitario, proveedores y terceros acceden con MFA, registro de accesos y condiciones específicas según perfil.
op.acc.6	Autenticación usuarios internos	Sí	C/I/T/A Media + MFA	Implantada	MFA para personal, TIC y administradores; bloqueo de sesión, contraseñas robustas y controles adicionales para privilegios elevados.
op.exp.1	Inventario de activos	Sí	Media - obligatoria	Implantada	CMDB corporativa con activos de información, software, hardware, redes, cloud, personal clave e instalaciones.
op.exp.2	Configuración de seguridad	Sí	Media - obligatoria	Implantada	Bastionado de servidores, endpoints, M365, LMS, firewalls y servicios cloud mediante guías CCN-STIC/CIS.
op.exp.3	Gestión de configuración de seguridad	Sí	Media + R1	Implantada	Repositorio de configuraciones, control de versiones, revisión de cambios y validación previa a producción.
op.exp.4	Mantenimiento y actualizaciones de seguridad	Sí	Media + R1	Implantada	Parches críticos en <=72h, altos en <=15 días, medios en <=60 días. Priorización por exposición y criticidad.
op.exp.5	Gestión de cambios	Sí	Media - obligatoria	Implantada	CAB corporativo, pruebas en preproducción y aprobación formal para cambios en LMS, ERP, IAM, red y cloud.
op.exp.6	Protección frente a código dañino	Sí	Media + R1/R2	Implantada	EDR corporativo, antimalware, bloqueo de macros, sandboxing de adjuntos y monitorización
op.exp.7	Gestión de incidentes	Sí	Media + R1/R2	Implantada	Procedimiento P1-P4, escalado a RSI/DPD/Dirección, registro de evidencias y notificación regulatoria cuando proceda.
op.exp.8	Registro de la actividad	Sí	T Media + refuerzos	Implantada	Logs centralizados en SIEM: IAM, LMS, VPN, firewall, EDR, servidores, BBDD y servicios cloud. Retención proporcional.
op.exp.9	Registro de gestión de incidentes	Sí	Media - obligatoria	Implantada	Ticketing integrad. Registro de triaje, contención, análisis, erradicación, recuperación y lecciones aprendidas.
op.exp.10	Protección de claves criptográficas	Sí	Media + R1	Implantada	Custodia de claves en almacenes seguros/HSM cloud cuando aplique; rotación, separación de funciones y acceso restringido.
op.ext.1	Contratación y acuerdos de nivel de servicio	No	Media - obligatoria	No aplica	No aplica ya que todos estos contratos con terceros se llevan a cabo internamente en la empresa.
op.ext.2	Gestión diaria de proveedores	Sí	Media - obligatoria	Implantada	Revisión periódica de proveedores críticos: LMS, cloud, M365, conectividad y soporte externo.
op.ext.3	Protección de la cadena de suministro	Sí	Adicional por riesgo	Parcial	Para proveedores cloud/LMS y subcontratistas. Medida aplicada por dependencia de terceros
op.ext.4	Interconexión de sistemas	Sí	Media - obligatoria	Implantada	Control de integraciones entre sedes, cloud, LMS, ERP, M365, VPN y redes de invitados. Revisión de puntos de interconexión.
op.nub.1	Protección de servicios en la nube	Sí	Media + R1	Implantada	Configuración segura de AWS/Azure/M365, cifrado, IAM cloud, registro de actividad, revisión de permisos y respaldo contractual.
op.cont.1	Análisis de impacto	Sí	Dimensión D - Media	Implantada	BIA corporativo para LMS, ERP, correo, WiFi, Internet, sistemas y procesos académicos críticos.
op.cont.2	Plan de continuidad	Sí	Adicional por riesgo	Implantada	PCN aplicado, aunque no siempre sea exigible en Media, por continuidad docente, evaluación, matrícula y comunicación familias.
op.cont.3	Pruebas periódicas	Sí	Adicional por riesgo	Implantada	Simulacro anual y pruebas trimestrales de restauración. Participan TIC central y responsables TIC locales.
op.cont.4	Medios alternativos	Sí	Adicional por riesgo	Implantada	Conectividad redundante, modo degradado LMS, copias offsite, contingencia 4G/5G y operación alternativa por centro.

Código	Control ENS	Aplica	Nivel / refuerzo	Estado	Justificación global / evidencia prevista
op.mon.1	Detección de intrusión	Sí	Media + R1	Implantada	Reglas SIEM orientadas a ransomware, phishing, DDoS y explotación del LMS.
op.mon.2	Sistema de métricas	Sí	Media + R1/R2	Implantada	Cuadro de mando semestral: parches, incidentes, MFA, formación, vulnerabilidades, backups, proveedores y cobertura SIEM.
op.mon.3	Vigilancia	Sí	Media + R1/R2	Implantada	Monitorización continua por, threat intelligence, detección de anomalías y revisión periódica de vulnerabilidades.
mp.if.1	Áreas separadas y control de acceso	No	Media - obligatoria	No aplica	No aplica debido a que las instalaciones de nuestros servidores donde se gestiona el sistema de la app, lo lleva un tercero
mp.if.2	Identificación de las personas	No	Media - obligatoria	No aplica	No aplica ya que no debemos hacernos cargo de la identificación del personal que se encuentra en las instalaciones ya que se trata de terceros.
mp.if.3	Acondicionamiento de locales	No	Media - obligatoria	No aplica	No aplica debido a que al tratarse de un tercero no nos encargamos del acondicionamiento de los locales.
mp.if.4	Energía eléctrica	No	D Media + R1	No aplica	No aplica ya que no nos encargamos ya que depende del tercero.
mp.if.5	Protección frente a incendios	No	Media - obligatoria	No aplica	No aplica ya que la infraestructura es responsabilidad de los terceros.
mp.if.6	Protección frente a inundaciones	No	D Media	No aplica	No aplica ya que no nos hacemos responsable de lo que suceda en los locales, ya que la responsabilidad es de terceros.
mp.if.7	Registro de entrada/salida de equipamiento	No	Media - obligatoria	No aplica	No aplica ya que el responsable del registro de entradas y salidas es del tercero es responsabilidad del tercero.
mp.per.1	Caracterización del puesto de trabajo	Sí	Media - obligatoria	Implantada	Perfiles de puesto con requisitos de seguridad, confidencialidad y acceso según función docente, PAS, TIC o directiva.
mp.per.2	Deberes y obligaciones	Sí	Media + R1	Implantada	AUP, confidencialidad, obligaciones RGPD, deber de custodia de credenciales y régimen disciplinario.
mp.per.3	Concienciación	Sí	Media - obligatoria	Implantada	Formación anual, simulaciones de phishing y comunicación de buenas prácticas a todo el personal.
mp.per.4	Formación	Sí	Media - obligatoria	Implantada	Formación específica para TIC en ENS, gestión de incidentes, bastionado, forense básica y protección de menores.
mp.eq.1	Puesto de trabajo despejado	Sí	Media + R1	Implantada	Política de escritorio limpio, bloqueo de pantallas y tratamiento seguro de documentación física.
mp.eq.2	Bloqueo de puesto de trabajo	Sí	A Media	Implantada	Bloqueo automático a 5 minutos, autenticación para desbloqueo y controles GPO/MDM.
mp.eq.3	Protección de dispositivos portátiles	Sí	Media - obligatoria	Implantada	Cifrado completo, MDM, EDR, VPN, borrado remoto y prohibición de almacenamiento local no autorizado.
mp.eq.4	Otros dispositivos conectados a la red	Sí	C Media + R1	Implantada	Segmentación IoT/VR/AR, inventario de dispositivos y autorización previa antes de conexión a red corporativa.
mp.com.1	Perímetro seguro	Sí	Media - obligatoria	Implantada	NGFW, DMZ, reglas de filtrado, proxy, WAF y revisión de exposición.
mp.com.2	Protección de la confidencialidad	Sí	C Media + R1	Implantada	TLS 1.3, VPN, cifrado de enlaces SD-WAN, protección de datos de menores
mp.com.3	Protección de integridad y autenticidad	Sí	I/A Media + R1/R2	Implantada	Certificados, firma electrónica, control de integridad, hash de evidencias y validación de comunicaciones.
mp.com.4	Separación de flujos de información en red	Sí	Media + R1/R2/R3	Implantada	VLAN y políticas separadas para alumnos, docentes/PAS, servidores, gestión, invitados, IoT/VR y proveedores.
mp.si.1	Marcado de soportes	Sí	C Media	Implantada	Etiquetado de soportes según clasificación: Público, Uso Interno, Confidencial y Secreto.
mp.si.2	Criptografía	No	C/I Media	No aplica	No se aplica ya que nuestra compañía no se encarga de la criptografía y es llevada por un tercero
mp.si.3	Custodia	Sí	Media - obligatoria	Implantada	Custodia de soportes y copias en ubicaciones protegidas, con acceso restringido y trazabilidad.
mp.si.4	Transporte	Sí	Media - obligatoria	Implantada	Cifrado de soportes extraíbles, registro de movimientos y transporte por canales autorizados.
mp.si.5	Borrado y destrucción	Sí	C Media + R1	Implantada	Borrado seguro lógico y destrucción certificada de soportes al final de vida útil.
mp.sw.1	Desarrollo de aplicaciones	No	Media + R1/R2/R3/R4	No aplica	No se aplica ya que no somos una compañía de desarrollo de aplicaciones y ha sido desarrollada por un tercero.
mp.sw.2	Aceptación y puesta en servicio	Sí	Media + R1	Implantada	Pruebas funcionales y de seguridad, aprobación de RSI y responsable del servicio antes de producción.
mp.info.1	Datos personales	Sí	Media - obligatoria	Implantada	RAT, EIPD para menores, minimización, base jurídica, derechos y medidas RGPD/LOPDGDD.
mp.info.2	Clasificación de la información	Sí	C Media	Implantada	Clasificación corporativa de información y reglas de tratamiento por nivel.
mp.info.3	Firma electrónica	Sí	I/A Media + refuerzos	Implantada	Firma electrónica en documentos académicos, autorizaciones, actas y evidencias de auditoría relevantes.
mp.info.4	Sellos de tiempo	Sí	Adicional por riesgo	Planificada	Sellado temporal para evidencias críticas, registros de auditoría y documentos académicos con efectos probatorios.
mp.info.5	Limpieza de documentos	Sí	C Media	Implantada	Revisión de metadatos, anonimización cuando proceda y control de documentos antes de publicación o envío externo.
mp.info.6	Copias de seguridad	Sí	D Media + R1	Implantada	Copias cifradas, pruebas trimestrales de restauración
mp.s.1	Protección del correo electrónico	Sí	Media - obligatoria	Implantada	Antiphishing, sandboxing, formación y reporte rápido
mp.s.2	Protección de servicios y aplicaciones web	Sí	Media + R1/R2	Implantada	WAF, HTTPS, escaneos mensuales, pentest anual y bastionado de LMS, app móvil y portales.
mp.s.3	Protección de la navegación web	Sí	Media - obligatoria	Implantada	Proxy, filtrado DNS/URL, inspección de malware y bloqueo de categorías de riesgo.
mp.s.4	Protección frente a denegación de servicio	Sí	D Media	Implantada	Protección AntiDDoS en CDN/cloud, reglas perimetrales y planes de escalado ante indisponibilidad.

5.4.5 SOC interno

La inclusión del SOC dentro del SGSI se justifica por su papel crítico en la detección temprana de incidentes y en la respuesta coordinada ante ciberataques, siendo un elemento clave para garantizar los principios de seguridad de la información CIDAT. Además, el SOC actúa como componente central en la gestión operativa de la seguridad, integrando tecnologías como SIEM, IDS/IPS y herramientas de análisis de vulnerabilidades, y facilitando la correlación de eventos en tiempo real.

Hemos decidido incluir este sistema porque permite una monitorización continua de todos los sistemas incluidos en el SGSI, mejora la capacidad de detección y respuesta ante incidentes de seguridad, reduce el impacto de posibles amenazas mediante una respuesta rápida y estructurada.

INVENTARIO Y VALORACIÓN DE ACTIVOS

ID	Nombre del activo	Tipo	Confidenc.	Integrid.	Disponib.	Autenticid.	Trazabil.
INF-11	Logs de seguridad (SIEM)	Información	Alta	Alta	Alta	Alta	Alta
INF-12	Alertas de seguridad	Información	Alta	Alta	Alta	Alta	Alta
INF-13	Informes de Incidentes	Información	Alta	Alta	Media	Alta	Alta
INF-14	Inteligencia de amenazas	Información	Media	Alta	Media	Media	Media
SW-06	Herramienta de análisis de vulnerabilidades	Software	Media	Alta	Media	Media	Media
NET-01	Red de monitorización	Infraestructura	Media	Alta	Alta	Media	Media
PER-01	Analistas SOC	Personas	Alta	Alta	Alta	Alta	Alta

IDENTIFICACIÓN Y EVALUACIÓN DE AMENAZAS

Activo	Amenaza	Probabilidad (justificación)	Impacto (consecuencia)	Efecto (resultado, probab + impacto)	Tratamiento (tecnología. Normativa o personas)	Prioridad
INF-11	Manipulación o borrado de logs	Media, posible por accesos indebidos o ataques internos	Pérdida de trazabilidad	Imposibilidad de auditoría y análisis forense	Tecnología (logs inmutables), normativa (control de accesos), personas (auditorías)	1- Crítica
INF-12	Saturación de alertas (alert fatigue)	Alta en entornos con mucho volumen de eventos	Incidentes no atendidos	Fallo en detección temprana	Tecnología (correlación SIEM), personas (procedimientos)	2- Alta
SW-06	Herramientas desactualizadas	Media, si no se mantienen correctamente	Vulnerabilidades no detectadas	Sistemas expuestos	Tecnología (actualizaciones periódicas)	2- Alta
PER-01	Error humano de analistas	Alta, factor humano	Mala gestión de incidentes	Impacto en respuesta	Personas (formación, procedimientos)	2- Alta

DECLARACIÓN DE APLICABILIDAD (SOC interno)

Código	Control ENS	Aplica	Nivel / refuerzo	Estado	Justificación global / evidencia prevista
org.1	Política de seguridad	Sí	Media - obligatoria	Implantada	Política corporativa aprobada por Dirección. Define misión educativa, marco legal, roles, comité, documentación y riesgos derivados del tratamiento de datos personales.
org.2	Normativa de seguridad	Sí	Media - obligatoria	Implantada	Normas internas de uso aceptable, clasificación de la información, dispositivos móviles, teletrabajo, IA, correo y tratamiento de datos de menores.
org.3	Procedimientos de seguridad	Sí	Media - obligatoria	Implantada	Procedimientos comunes para operación, reporte de anomalías, copias, etiquetado, transmisión segura, gestión de cambios e incidentes en los 17 centros.
org.4	Proceso de autorización	Sí	Media - obligatoria	Implantada	Autorización formal para altas de usuarios, entrada de sistemas en producción, servicios cloud, soportes, comunicaciones y proveedores.
op.pl.1	Análisis de riesgos	Sí	Media + R1	Implantada	Análisis semiformal MAGERIT con activos, amenazas, salvaguardas y riesgo residual. Revisión anual y ante cambios relevantes.
op.pl.2	Arquitectura de seguridad	Sí	Media + R1	Implantada	Arquitectura documentada con líneas de defensa: IAM, segmentación, NGFW, DMZ, SIEM, EDR, cloud híbrido y controles de datos sensibles.
op.pl.3	Adquisición de nuevos componentes	Sí	Media - obligatoria	Implantada	Proceso de aprobación TIC/RSI antes de adquirir LMS, servicios cloud, aplicaciones educativas o componentes de seguridad.
op.pl.4	Dimensionamiento / gestión de la capacidad	Sí	Dimensión D - Media + R1	Implantada	Capacidad monitorizada para LMS, ERP, WiFi, M365 y cloud. Previsión de demanda en exámenes, matrículas e inicio de curso.
op.pl.5	Componentes certificados	Sí	Media - obligatoria	Parcial	Preferencia por productos y servicios cualificados en CPSTIC/CCN o con certificaciones reconocidas. Plan de madurez para proveedores cloud y seguridad.
op.acc.1	Identificación	Sí	T/A Media + R1	Implantada	Identificadores únicos y nominales en IAM corporativo; separación de perfiles alumno, docente, PAS, TIC y administrador.
op.acc.2	Requisitos de acceso	Sí	C/I/T/A Media	Implantada	Accesos protegidos por mínimo privilegio, necesidad de conocer y matrices de permisos por perfil profesional y servicio.
op.acc.3	Segregación de funciones y tareas	Sí	C/I/T/A Media	Implantada	Separación entre RSI, responsable del sistema, operación, auditoría, desarrollo y aprobación de cambios críticos.
op.acc.4	Gestión de derechos de acceso	Sí	C/I/T/A Media	Implantada	Altas, modificaciones y bajas mediante IAM; revisión semestral; deshabilitación de accesos tras baja o cambio de rol.
op.acc.5	Autenticación usuarios externos	Sí	C/I/T/A Media + MFA/registro	Implantada	Familias, alumnado universitario, proveedores y terceros acceden con MFA, registro de accesos y condiciones específicas según perfil.
op.acc.6	Autenticación usuarios internos	Sí	C/I/T/A Media + MFA	Implantada	MFA para personal, TIC y administradores; bloqueo de sesión, contraseñas robustas y controles adicionales para privilegios elevados.
op.exp.1	Inventario de activos	Sí	Media - obligatoria	Implantada	CMDB corporativa con activos de información, software, hardware, redes, cloud, personal clave e instalaciones.
op.exp.2	Configuración de seguridad	Sí	Media - obligatoria	Implantada	Bastionado de servidores, endpoints, M365, LMS, firewalls y servicios cloud mediante guías CCN-STIC/CIS.
op.exp.3	Gestión de configuración de seguridad	Sí	Media + R1	Implantada	Repositorio de configuraciones, control de versiones, revisión de cambios y validación previa a producción.
op.exp.4	Mantenimiento y actualizaciones de seguridad	Sí	Media + R1	Implantada	Parches críticos en <=72h, altos en <=15 días, medios en <=60 días. Priorización por exposición y criticidad.
op.exp.5	Gestión de cambios	Sí	Media - obligatoria	Implantada	CAB corporativo, pruebas en preproducción y aprobación formal para cambios en LMS, ERP, IAM, red y cloud.
op.exp.6	Protección frente a código dañino	Sí	Media + R1/R2	Implantada	EDR corporativo, antimalware, bloqueo de macros, sandboxing de adjuntos y monitorización
op.exp.7	Gestión de incidentes	Sí	Media + R1/R2	Implantada	Procedimiento P1-P4, escalado a RSI/DPD/Dirección, registro de evidencias y notificación regulatoria cuando proceda.
op.exp.8	Registro de la actividad	Sí	T Media + refuerzos	Implantada	Logs centralizados en SIEM: IAM, LMS, VPN, firewall, EDR, servidores, BBDD y servicios cloud. Retención proporcional.
op.exp.9	Registro de gestión de incidentes	Sí	Media - obligatoria	Implantada	Ticketing integrad. Registro de triaje, contención, análisis, erradicación, recuperación y lecciones aprendidas.
op.exp.10	Protección de claves criptográficas	Sí	Media + R1	Implantada	Custodia de claves en almacenes seguros/HSM cloud cuando aplique; rotación, separación de funciones y acceso restringido.
op.ext.1	Contratación y acuerdos de nivel de servicio	Sí	Media - obligatoria	Implantada	Contratos con cláusulas de seguridad, confidencialidad, RGPD, auditoría, notificación de incidentes y devolución/destrucción de datos.
op.ext.2	Gestión diaria de proveedores	Sí	Media - obligatoria	Implantada	Revisión periódica de proveedores críticos: LMS, cloud, M365, conectividad y soporte externo.
op.ext.3	Protección de la cadena de suministro	Sí	Adicional por riesgo	Parcial	Para proveedores cloud/LMS y subcontratistas. Medida aplicada por dependencia de terceros
op.ext.4	Interconexión de sistemas	Sí	Media - obligatoria	Implantada	Control de integraciones entre sedes, cloud, LMS, ERP, M365, VPN y redes de invitados. Revisión de puntos de interconexión.
op.nub.1	Protección de servicios en la nube	Sí	Media + R1	Implantada	Configuración segura de AWS/Azure/M365, cifrado, IAM cloud, registro de actividad, revisión de permisos y respaldo contractual.
op.cont.1	Análisis de impacto	Sí	Dimensión D - Media	Implantada	BIA corporativo para LMS, ERP, correo, WiFi, Internet, sistemas y procesos académicos críticos.
op.cont.2	Plan de continuidad	Sí	Adicional por riesgo	Implantada	PCN aplicado, aunque no siempre sea exigible en Media, por continuidad docente, evaluación, matrícula y comunicación familias.
op.cont.3	Pruebas periódicas	Sí	Adicional por riesgo	Implantada	Simulacro anual y pruebas trimestrales de restauración. Participan TIC central y responsables TIC locales.
op.cont.4	Medios alternativos	Sí	Adicional por riesgo	Implantada	Conectividad redundante, modo degradado LMS, copias offsite, contingencia 4G/5G y operación alternativa por centro.
op.mon.1	Detección de intrusión	Sí	Media + R1	Implantada	Reglas SIEM orientadas a ransomware, phishing, DDoS y explotación del LMS.
op.mon.2	Sistema de métricas	Sí	Media + R1/R2	Implantada	Cuadro de mando semestral: parches, incidentes, MFA, formación, vulnerabilidades, backups, proveedores y cobertura SIEM.

Código	Control ENS	Aplica	Nivel / refuerzo	Estado	Justificación global / evidencia prevista
op.mon.3	Vigilancia	Sí	Media + R1/R2	Implantada	Monitorización continua por, threat intelligence, detección de anomalías y revisión periódica de vulnerabilidades.
mp.if.1	Áreas separadas y control de acceso	Sí	Media - obligatoria	Implantada	Zonas controladas y acceso restringido al personal autorizado y registro de entradas.
mp.if.2	Identificación de las personas	Sí	Media - obligatoria	Implantada	Tarjeta corporativa, control de visitantes y verificación de identidad para acceso a zonas sensibles.
mp.if.3	Acondicionamiento de locales	Sí	Media - obligatoria	Implantada	Climatización, sensores ambientales, control de humedad, detección de humo y mantenimiento preventivo en instalaciones
mp.if.4	Energía eléctrica	Sí	D Media + R1	Implantada	SAI, grupo electrógeno y redundancia eléctrica para sedes principales.
mp.if.5	Protección frente a incendios	Sí	Media - obligatoria	Implantada	Detección y extinción automática y procedimientos de evacuación y revisión periódica.
mp.if.6	Protección frente a inundaciones	Sí	D Media	Implantada	Sensores de agua, ubicación elevada de equipos, revisión de riesgos físicos y plan de contingencia.
mp.if.7	Registro de entrada/salida de equipamiento	Sí	Media - obligatoria	Implantada	Registro de salida, entrada, reparación y baja de equipos TIC, soportes y dispositivos móviles corporativos.
mp.per.1	Caracterización del puesto de trabajo	Sí	Media - obligatoria	Implantada	Perfiles de puesto con requisitos de seguridad, confidencialidad y acceso según función docente, PAS, TIC o directiva.
mp.per.2	Deberes y obligaciones	Sí	Media + R1	Implantada	AUP, confidencialidad, obligaciones RGPD, deber de custodia de credenciales y régimen disciplinario.
mp.per.3	Concienciación	Sí	Media - obligatoria	Implantada	Formación anual, simulaciones de phishing y comunicación de buenas prácticas a todo el personal.
mp.per.4	Formación	Sí	Media - obligatoria	Implantada	Formación específica para TIC en ENS, gestión de incidentes, bastionado, forense básica y protección de menores.
mp.eq.1	Puesto de trabajo despejado	Sí	Media + R1	Implantada	Política de escritorio limpio, bloqueo de pantallas y tratamiento seguro de documentación física.
mp.eq.2	Bloqueo de puesto de trabajo	Sí	A Media	Implantada	Bloqueo automático a 5 minutos, autenticación para desbloqueo y controles GPO/MDM.
mp.eq.3	Protección de dispositivos portátiles	Sí	Media - obligatoria	Implantada	Cifrado completo, MDM, EDR, VPN, borrado remoto y prohibición de almacenamiento local no autorizado.
mp.eq.4	Otros dispositivos conectados a la red	Sí	C Media + R1	Implantada	Segmentación IoT/VR/AR, inventario de dispositivos y autorización previa antes de conexión a red corporativa.
mp.com.1	Perímetro seguro	Sí	Media - obligatoria	Implantada	NGFW, DMZ, reglas de filtrado, proxy, WAF y revisión de exposición externa.
mp.com.2	Protección de la confidencialidad	Sí	C Media + R1	Implantada	TLS 1.3, VPN, cifrado de enlaces SD-WAN, protección de datos de menores
mp.com.3	Protección de integridad y autenticidad	Sí	I/A Media + R1/R2	Implantada	Certificados, firma electrónica, control de integridad, hash de evidencias y validación de comunicaciones.
mp.com.4	Separación de flujos de información en red	Sí	Media + R1/R2/R3	Implantada	VLAN y políticas separadas para alumnos, docentes/PAS, servidores, gestión, invitados, IoT/VR y proveedores.
mp.si.1	Marcado de soportes	Sí	C Media	Implantada	Etiquetado de soportes según clasificación: Público, Uso Interno, Confidencial y Secreto.
mp.si.2	Criptografía	Sí	C/I Media	Implantada	AES-256 en reposo, TLS 1.3 en tránsito, claves gestionadas y políticas de uso criptográfico.
mp.si.3	Custodia	Sí	Media - obligatoria	Implantada	Custodia de soportes y copias en ubicaciones protegidas, con acceso restringido y trazabilidad.
mp.si.4	Transporte	Sí	Media - obligatoria	Implantada	Cifrado de soportes extraíbles, registro de movimientos y transporte por canales autorizados.
mp.si.5	Borrado y destrucción	Sí	C Media + R1	Implantada	Borrado seguro lógico y destrucción certificada de soportes al final de vida útil.
mp.sw.1	Desarrollo de aplicaciones	No	Media + R1/R2/R3/R4	No aplica	El SOC no desarrolla software, utiliza herramientas existentes.
mp.sw.2	Aceptación y puesta en servicio	Sí	Media + R1	Implantada	Pruebas funcionales y de seguridad, aprobación de RSI y responsable del servicio antes de producción.
mp.info.1	Datos personales	Sí	Media - obligatoria	Implantada	RAT, EIPD para menores, minimización, base jurídica, derechos y medidas RGPD/LOPDGDD.
mp.info.2	Calificación de la información	Sí	C Media	Implantada	Clasificación corporativa de información y reglas de tratamiento por nivel.
mp.info.3	Firma electrónica	Sí	I/A Media + refuerzos	Implantada	Firma electrónica en documentos académicos, autorizaciones, actas y evidencias de auditoría relevantes.
mp.info.4	Sellos de tiempo	Sí	Adicional por riesgo	Planificada	Sellado temporal para evidencias críticas, registros de auditoría y documentos académicos con efectos probatorios.
mp.info.5	Limpieza de documentos	No	C Media	No aplica	El SOC se centra en eventos y logs, no los metadatos.
mp.info.6	Copias de seguridad	Sí	D Media + R1	Implantada	Copias cifradas, pruebas trimestrales de restauración
mp.s.1	Protección del correo electrónico	Sí	Media - obligatoria	Implantada	Antiphishing, sandboxing, formación y reporte rápido
mp.s.2	Protección de servicios y aplicaciones web	Sí	Media + R1/R2	Implantada	WAF, HTTPS, escaneos mensuales, pentest anual y bastionado de LMS, app móvil y portales.
mp.s.3	Protección de la navegación web	Sí	Media - obligatoria	Implantada	Proxy, filtrado DNS/URL, inspección de malware y bloqueo de categorías de riesgo.
mp.s.4	Protección frente a denegación de servicio	Sí	D Media	Implantada	Protección AntiDDoS en CDN/cloud, reglas perimetrales y planes de escalado ante indisponibilidad.

6. CONTROLES DE SEGURIDAD OPERACIONALES

6.1. Gestión de identidades y control de accesos

ATHENEA, S. A. dispone de un sistema centralizado de gestión de identidades (IAM) basado en Microsoft Azure Active Directory, federado con los sistemas locales de los 17 centros mediante Azure AD Connect. Los principios de aplicación son mínimo privilegio, necesidad de conocer y separación de funciones.

- Cuentas nominativas obligatorias para todos los usuarios (docentes, PAS, alumnos universitarios y TIC). Sin cuentas compartidas ni genéricas.
- Autenticación multifactor (MFA) obligatoria para: acceso a sistemas críticos (LMS, ERP, BBDD), correo corporativo, VPN y operaciones administrativas privilegiadas.
- Contraseñas con longitud mínima de 14 caracteres, combinando al menos 3 de los 4 tipos de caracteres. Renovación máxima cada 180 días. Sin reutilización de las últimas 12 contraseñas.
- Acceso remoto exclusivamente a través de VPN corporativa con MFA y certificado de dispositivo gestionado.
- Los alumnos de primaria y secundaria no tendrán acceso a sistemas corporativos; sus cuentas LMS estarán aisladas en un dominio separado con controles de acceso reforzados.
- Revisión formal de derechos de acceso con periodicidad semestral. Baja de accesos en un plazo máximo de 24 horas tras la notificación de cese de empleado o alumno.

6.2. Protección Especial de Datos de Menores

Dado que ATHENEA, S. A. trata datos de menores de edad (alumnos de primaria, ESO y bachillerato) se aplican las siguientes salvaguardas adicionales, conforme al artículo 9 RGPD, la LOPDGD y la LOPIVI:

- Solo pueden acceder a estos datos que utilicen estos datos para su trabajo (docentes o personal administrativo autorizado).
- Los datos están protegidos mediante sistemas de seguridad (como cifrado y control de accesos) para evitar accesos no autorizados.
- Se mantienen logs de los accesos a los datos de los menores de edad, para mantener la trazabilidad de los datos y saber quién ha accedido y qué se han hecho con los datos.
- Solo se recogen los datos necesarios y esenciales.
- En caso de incidente, se actúa de forma prioritaria para minimizar el impacto sobre los menores.

6.3. Seguridad en la Infraestructura Multicampus

Para garantizar la seguridad en la red distribuida de los 17 centros, se aplican controles de segmentación y gestión centralizada:

- Red WiFi 6 multicampus segmentada mediante VLANs: red de usuarios (docentes/PAS), red de alumnos, red de gestión/TIC, red de dispositivos IoT/laboratorios VR-AR, red de invitados. Cada segmento con políticas de firewall independientes.

- NGFW (Next Generation Firewall) desplegado en cada CPD y en las sedes principales, con gestión centralizada desde el SOC.
- Acceso seguro a servicios corporativos desde los centros remotos a través de túneles SD-WAN cifrados con monitorización de tráfico en tiempo real.
- Inspección SSL/TLS del tráfico saliente en todos los centros mediante proxy corporativo, con excepciones documentadas y aprobadas por el Responsable de Seguridad.

6.4. Seguridad del LMS y plataformas educativas

Para garantizar la integridad y disponibilidad de las herramientas de aprendizaje (Moodle y Blackboard), se aplican medidas de endurecimiento y protección de capa de aplicación:

- Moodle y Blackboard ejecutan en entornos endurecidos. Versiones actualizadas con parches de seguridad aplicados en menos de 72 horas para vulnerabilidades críticas.
- WAF (Web Application Firewall) activo en las dos plataformas LMS con reglas actualizadas mensualmente.
- Pruebas de penetración (pentest) anuales sobre el LMS, la app móvil y el portal web académico, realizadas por empresa externa independiente.
- Separación de entornos: producción, pre-producción y desarrollo en redes aisladas. Prohibido el uso de datos reales en entornos de desarrollo/pruebas.
- Los contenidos de los laboratorios VR/AR son accesibles únicamente desde la red interna de los centros, con autenticación de usuario.

6.5. Operaciones y Monitorización

Centraliza la detección, investigación y respuesta ante eventos de seguridad. El SIEM recibirá logs de IAM, LMS, VPN, firewalls, WAF, EDR, servidores, BBDD, cloud y sistemas críticos.

Las reglas de detección se orientan específicamente a la identificación de ataques de: phishing, robo de credenciales, ransomware, movimientos laterales, abuso de privilegios, exfiltración y explotación de vulnerabilidades.

6.6. Política de Continuidad y Copias de Seguridad

Se establece una estrategia de copias de seguridad basada en la criticidad de los activos, asegurando la recuperación ante desastres:

Sistema	Frecuencia	Retención	RTO	RPO	Almacenamiento
LMS	Incremental diaria + completa semanal	90 días	4 h	1 h	NAS local + cloud cifrado
BBDD alumnos/menores	Incremental cada 6 h	1 año	2 h	30 min	NAS cifrado + offsite
BBDD general	Completa diaria	6 meses	4 h	1 h	NAS cifrado + offsite
ERP académico	Completa diaria	1 año	8 h	4 h	NAS + cloud + offsite

Configuraciones red/sistemas	Ante cada cambio	1 año	2 h	N/A	Repositorio
-------------------------------------	------------------	-------	-----	-----	-------------

Trimestralmente se realizarán pruebas de restauración en entornos aislados para validar la integridad de los datos. Los informes de resultados quedarán documentados y serán comunicados al CSI.

6.7. Gestión de proveedores y terceros

Dada la dependencia de plataformas cloud (AWS, Azure, M365) y de los propios proveedores del LMS (Moodle, Blackboard), se aplicará el siguiente marco de gestión de terceros:

- Todos los contratos con proveedores que accedan a datos personales incluirán cláusula de Encargado de Tratamiento (art. 28 RGPD), con obligaciones de seguridad, confidencialidad, notificación de incidentes en un plazo máximo de 24 horas, derechos de auditoría y condiciones de devolución/destrucción de datos.
- Revisión anual del cumplimiento de los proveedores existentes.
- Los accesos remotos de soporte técnico por parte de terceros serán grabados, limitados temporalmente y supervisados en tiempo real.
- Debido a la alta dependencia de servicios en la nube, se aplica de forma reforzada la medida [op.ext.3] Seguridad de los servicios externos, exigiendo certificaciones de seguridad actualizadas (ISO 27001 / ENS) a todos los proveedores críticos.

7. GESTIÓN DE INCIDENTES DE SEGURIDAD

7.1. Objetivo

Garantizar la respuesta rápida, coordinada y efectiva ante cualquier incidente de seguridad que comprometa la confidencialidad, integridad, disponibilidad, autenticidad o trazabilidad de los activos de ATHENEA, S. A. Se priorizará la protección de datos de menores minimizando el impacto y asegurando el cumplimiento de los plazos legales de notificación.

7.2. Clasificación de Incidentes y Tiempos de Respuesta

La severidad del incidente determina el flujo de escalado y los tiempos máximos de intervención:

Nivel	Severidad	Criterios / Ejemplos	Tiempo de respuesta	Notificación Externa
P1	CRÍTICO	Ransomware activo, brecha masiva de datos de menores, compromiso del AD o caída global de servicios	< 30 min.	AEPD (máximo 72 horas), CCN-CERT, CSI
P2	ALTO	Exfiltración de datos, cuenta administrativa comprometida o malware en servidor crítico.	< 2 h.	Responsable de Seguridad y DPD

P3	MEDIO	Intento de intrusión fallido, vulnerabilidad crítica detectada o anomalías en el acceso al LMS.	< 8 h.	Responsable de Seguridad y Responsable TIC local
P4	BAJO	Phishing bloqueado, escaneo de puertos o infracciones menores de la política de seguridad.	< 24 h.	Responsable TIC local

7.3. Flujo de gestión de incidentes

Fase 1 — Detección e identificación

Los incidentes pueden ser detectados por el SOC (mediante SIEM/IDS), usuarios o los Responsables TIC locales. Cualquier usuario que detecte o sospeche de un incidente notificará de inmediato al canal oficial: incidentes@athenea.es. El triaje inicial se realizará en un plazo máximo de 15 minutos para incidentes P1 y 30 minutos para el resto.

Fase 2 — Contención

Aplicación de medidas inmediatas de contención para frenar la propagación: aislamiento del sistema o segmento de red afectado, bloqueo de cuentas comprometidas, revocación de certificados si procede y preservación de evidencias forenses para análisis posterior.

Fase 3 — Análisis forense

El equipo de respuesta a incidentes (Responsable de Seguridad y SOC) realizará el análisis de causa raíz mediante técnicas forenses digitales: análisis de logs del SIEM, análisis de malware en sandbox, revisión de registros de acceso y reconstrucción del vector de ataque.

Fase 4 — Erradicación

Eliminación de la amenaza: limpieza de malware, cierre de puertos, rotación de credenciales y parcheo de vulnerabilidades explotadas.

Fase 5 — Recuperación

Restauración gradual de los servicios desde copias de seguridad verificadas. Se mantendrá una monitorización intensiva durante las 72 horas posteriores a la puesta en producción.

Fase 6 — Lecciones aprendidas

En un plazo máximo de 5 días laborables tras el cierre del incidente, se elaborará el Informe Post-Incidente (IPI) que incluirá: cronología detallada, causa raíz, impacto cuantificado, medidas correctoras implantadas y recomendaciones. El IPI se presentará al CSI y se incorporará al registro de incidentes para su análisis de tendencias.

7.4. Obligaciones de notificación regulatoria

- Brechas de datos personales: notificación a la AEPD en un plazo máximo de 72 horas desde el conocimiento del incidente, conforme al artículo 33 del RGPD. Si afecta a menores de edad, se valorará adicionalmente la notificación a la Fiscalía de Menores.

- Notificación a los interesados (art. 34 RGPD): si el riesgo es calificado como “Muy Alto” para los derechos y libertades de los afectados, especialmente menores, se comunicará a estos y a sus representantes legales, detallando las medidas adoptadas y recomendaciones de seguridad.

8. CONTINUIDAD DEL SERVICIO

8.1. Análisis de impacto en el negocio (BIA)

El BIA de ATHENEA, S. A. identifica los procesos y servicios críticos, cuantifica el impacto de una interrupción y determina los objetivos de recuperación. Dado el calendario académico, los períodos de mayor criticidad son: inicio de curso (septiembre), convocatorias de exámenes (enero, mayo-junio) y procesos de matrícula.

Proceso crítico	Identificador	Criticidad	RTO	RPO	MTD	% actividad
Bases de datos	BD-01	Alta	8 h.	4 h.	48 h.	95%
LMS	LMS-01	Crítica	4 h.	1 h.	24 h.	100%
Infraestructura de red	RED-01	Crítica	2 h.	N / A	8 h.	100%
App móvil	APP-01	Media	8 h.	4 h.	72 h.	40%
SOC interno	SOC-01	Alta	4 h.	1 h.	24 h.	100%

8.2. Estrategia de continuidad

- Arquitectura de alta disponibilidad: los sistemas críticos (LMS, ERP, BBDD) corren en arquitectura activo-activo sobre cloud híbrido (AWS+datacenter propio), con conmutación automática entre zonas de disponibilidad.
- Conectividad redundante: cada centro dispone de dos líneas de Internet de operadores distintos, con conmutación automática (failover). En caso de fallo total, se activará el acceso 4G/5G de emergencia.
- Copias de seguridad offsite: almacenadas en región AWS diferente a la principal y en soporte físico en ubicación segura separada de los CPDs.
- Modo degradado del LMS: definición de funcionamiento offline para los centros ante caída del LMS corporativo, con sincronización posterior.

8.3. Plan de continuidad de negocio (PCN)

El PCN de ATHENEA S.A. se estructura en tres fases:

1. Activación criterios y responsables para declarar la situación de contingencia y activar el PCN.
2. Operación en contingencia procedimientos alternativos para cada proceso crítico, responsables de recuperación por centro y sistemas de respaldo.
3. Vuelta a la normalidad procedimientos de transición de regreso a los sistemas principales, validación de integridad y comunicación a usuarios.
4. El PCN contempla dos escenarios principales: fallo de la plataforma tecnológica central (LMS/ERP/red)

8.4. Pruebas y mantenimiento

Se realizarán simulacros del PCN al menos una vez al año, preferentemente fuera del período académico activo. Los ejercicios incluirán la participación de los Responsables TIC locales de al menos 5 centros representativos. Los resultados se documentarán y las mejoras se incorporarán en el plazo de un mes.

9. FORMACIÓN Y CONCIENCIACIÓN

9.1. Plan de formación anual en seguridad

ATHENEA S.A. mantendrá un Plan de Formación y Concienciación en Seguridad de la Información adaptado a los distintos perfiles de la organización. Su diseño e implantación es responsabilidad del RSI, con la colaboración de la Dirección de RRHH.

Colectivo	Contenido	Modalidad	Periodicidad	Duración
Todo el personal (3.200+)	Política SGSI, phishing, contraseñas, RGPD básico, protección de menores, escritorio limpio	e-Learning + test	Anual	2 horas
Equipo TIC y SOC (200+)	ENS avanzado, MAGERIT, bastionado, respuesta a incidentes, análisis forense	Formación presencial / certificaciones	Anual + cont.	16 horas + cert.
Responsables TIC locales (17 centros)	Procedimientos del SGSI, gestión de incidentes locales, bastionado, revisión de accesos	Presencial + eLearning	Anual	8 horas
Dirección y Consejo de Administración	Gobierno de la seguridad, obligaciones legales, gestión de crisis, reputación	Sesión presencial	Anual	3 horas
Docentes y PAS con acceso a datos de menores	Protección datos menores (LOPDGDD/LOPIVI), uso seguro del LMS, incidentes con menores	e-Learning + evaluación	Anual	2 horas extra
Nuevas incorporaciones	Formación inicial de seguridad + firma de AUP y confidencialidad	Presencial	Al alta	2 horas

9.2. Ejercicios de simulación

- Mínimo 3 campañas de phishing simulado no anunciadas al año, con informe de resultados y formación reforzada para los colectivos con mayor tasa de error.

- Simulacro anual de gestión de incidentes (tabletop exercise) con el equipo de dirección, RSI, SOC y DPD.

9.3. Métricas de formación

- Porcentaje del personal con formación anual completada: objetivo $\geq 95\%$.
- Tasa de clics en simulaciones de phishing: objetivo $< 5\%$.
- Porcentaje de responsables TIC locales certificados en ENS/seguridad: objetivo $\geq 80\%$.
- Incidentes causados por error humano: seguimiento trimestral con tendencia decreciente anual.

10. AUDITORÍA Y REVISIÓN

10.1. Auditoría interna

El RSI coordinará al menos una auditoría interna de cumplimiento del ENS con carácter anual. El alcance cubrirá la totalidad de los controles de la DdA, con un muestreo de al menos 5 centros educativos (incluyendo ambas universidades) en cada ciclo. Las no conformidades se categorizarán y darán lugar a un plan de acción con responsables y plazos. El informe de auditoría se presentará al CSI en los 30 días siguientes a su finalización.

10.2. Auditoría externa

Conforme al artículo 31 del ENS, ATHENEA S.A. se someterá a auditoría externa por entidad acreditada con periodicidad bienal. Adicionalmente, la organización mantiene las auditorías de renovación de las certificaciones ISO 9001 e ISO 14001, cuyas sinergias se aprovecharán para reducir la carga auditora sobre los centros. Se estudiará la obtención de la declaración de conformidad con el ENS ante el CCN.

10.3. Revisión del SGSI por la Dirección

El CSI revisará el SGSI en sesión ordinaria semestral. La revisión anual más completa será elevada al Consejo de Administración e incluirá: informe de auditoría interna, estado del Plan de Tratamiento de Riesgos, resumen de incidentes del período, evolución de los KPIs, cambios en el entorno normativo o de amenazas y propuestas de mejora del RSI.

10.4. Indicadores clave de seguridad (KPIs)

Indicador	Frecuencia	Objetivo	Responsable
% parches críticos aplicados en $\leq 72h$	Mensual	100%	Director TIC / SOC
MTTR (tiempo medio resolución incidentes P1/P2)	Mensual	$< 2h$ (P1)	RSI / SOC
Incidentes P1 sin notificación AEPD en $\leq 72h$	Mensual	0	RSI / DPD
% personal formado (formación anual obligatoria)	Anual	$\geq 95\%$	RSI / RRHH
Tasa de clics en simulaciones de phishing	Trimestral	$< 5\%$	RSI
Vulnerabilidades críticas abiertas $> 72h$	Semanal	0	SOC / TIC

Controles ENS implantados / declarados (DdA)	Anual	100%	RSI
Éxito en pruebas de restauración de backups	Trimestral	100%	Director TIC
Cobertura de activos críticos en SIEM	Mensual	100%	SOC
SLA pentest anual LMS / app móvil realizado	Anual	100%	RSI

11. MEJORA CONTINUA

11.1. Gestión de no conformidades

Toda no conformidad detectada en auditorías, revisiones o incidentes generará un Registro de No Conformidad (RNC) con: descripción del hallazgo, evidencia, impacto potencial, causa raíz, acción correctiva propuesta, responsable y plazo. El cierre de cada RNC será validado por el RSI. Las no conformidades graves o reincidentes se elevarán al CSI.

11.2. Ciclo PDCA aplicado a ATHENEA

- PLAN: Definición de objetivos de seguridad por ejercicio académico, actualización del análisis de riesgos ante nuevas incorporaciones de centros o tecnologías (AR/VR, analítica IA), revisión de la DdA.
- DO: Implantación de controles, formación al personal (3.200+), despliegue de medidas técnicas en los 17 centros, gestión operativa del SOC.
- CHECK: Auditorías internas y externas, revisión de KPIs, análisis de incidentes, monitorización SOC, informes al CSI.
- ACT: Mejora de controles deficientes, incorporación de lecciones aprendidas de incidentes, actualización de procedimientos y respuesta a cambios normativos.

11.3. Gestión del cambio

Cualquier cambio significativo en la organización (incorporación de nuevos centros, adopción de nuevas tecnologías educativas, cambio de proveedor de LMS o cloud) será evaluado por el RSI para determinar su impacto en la seguridad y, si procede, actualizará el análisis de riesgos, la DdA y los procedimientos afectados, con aprobación del CSI.

Casos de cambio que requerirán revisión obligatoria del SGSI: apertura o cierre de un centro, cambio de plataforma LMS, incorporación de nuevos tratamientos de datos de menores o datos biométricos, cambio de proveedor cloud principal, modificación de la arquitectura de red multicampus.

ANEXO A – CLASIFICACIÓN DE LA INFORMACIÓN

Nivel	Nombre	Descripción	Ejemplos en ATHENEA
N1	Público	Sin restricciones. Destinada al público general.	Web corporativa, catálogo de programas, convocatorias públicas.
N2	Uso interno	Solo para personal de ATHENEA. Impacto moderado si se filtra.	Procedimientos internos, estadísticas académicas, comunicaciones internas, materiales docentes.
N3	Confidencial	Datos personales, económicos, académicos. Impacto grave si se divulga.	Expedientes académicos, datos personales de alumnos, nóminas, datos de investigación I+D+i.
N4	Secreto	Datos biométricos, datos de salud, claves criptográficas. Impacto muy grave.	Plantillas biométricas, historial médico universitario, contraseñas de sistemas críticos, claves de cifrado maestras.

ANEXO B – POLÍTICA DE USO ACEPTABLE DE LOS SISTEMAS

B.1 Ámbito

La presente política es de obligado cumplimiento para todo el personal de ATHENEA S.A. (docentes, PAS, equipo TIC y personal directivo) y para los terceros que accedan a los sistemas de información de la organización bajo cualquier modalidad contractual.

B.2 Usos permitidos

- Uso de los sistemas de información exclusivamente para el desempeño de las funciones laborales o docentes asignadas.
- Acceso solo a los sistemas, datos y aplicaciones para los que se cuenta con autorización expresa.
- Uso del correo corporativo para comunicaciones profesionales relacionadas con la actividad de ATHENEA S.A.

B.3 Usos prohibidos

- Compartir credenciales de acceso con cualquier persona, incluidos compañeros o supervisores.
- Instalar software no autorizado por el Departamento TIC en equipos corporativos o accesibles desde la red corporativa.
- Acceder, copiar, modificar o destruir datos de alumnos (especialmente menores) para fines distintos a los de la actividad docente o laboral asignada.
- Desactivar, eludir o interferir en los controles de seguridad: antivirus, VPN, MDM, filtrado de contenidos.
- Fotografiar, grabar o publicar datos de menores en sistemas o plataformas no autorizadas por ATHENEA S.A.
- Utilizar los sistemas corporativos para actividades personales de carácter comercial, ilegal o contrarias a los valores de la organización.

B.4 Protección especial de datos de menores

Los empleados con acceso a datos de menores tienen la obligación expresa de: no revelar datos de menores a personas no autorizadas, comunicar de inmediato al RSI cualquier acceso anómalo o pérdida de información relativa a menores y aplicar el principio de minimización de datos en todos los tratamientos.

ANEXO C – PROCEDIMIENTO DE ALTA, MODIFICACIÓN Y BAJA DE USUARIOS

C.1 Alta de usuario

1. RRHH notifica al responsable TIC corporativo (con ≥ 48 h de antelación) los datos del nuevo empleado, su puesto y los sistemas a los que necesita acceso, mediante el formulario FORM-IAM001.
2. El Responsable del Servicio correspondiente aprueba los permisos solicitados conforme a la Matriz de Control de Accesos por Perfil de Puesto.
3. El RSI revisa y valida que los accesos solicitados se ajustan al principio de mínimo privilegio.
4. El Departamento TIC crea la cuenta en Azure AD con los permisos aprobados y asigna el dispositivo gestionado (con MDM).
5. El usuario recibe la bienvenida TIC, sus credenciales iniciales (con cambio obligatorio en el primer acceso) y firma el Acuerdo de Uso Aceptable (AUP).
6. Se registra el alta en el Sistema IAM con fecha, usuario, permisos concedidos, aprobadores y evidencias.

C.2 Modificación de accesos

1. Cualquier cambio de puesto, proyecto o responsabilidad que conlleve cambio de permisos requerirá un nuevo formulario FORM-IAM-001 con la aprobación del Responsable del Servicio y el RSI.
2. Los permisos anteriores incompatibles con el nuevo rol se revocarán de forma inmediata (segregación de funciones).

C.3 Baja de usuario

1. Ante notificación de baja (voluntaria, disciplinaria o fin de contrato), RRHH comunicará al RSI y al Departamento TIC con la máxima antelación posible y siempre antes del último día de trabajo.
2. Todos los accesos del usuario (AD, M365, LMS, VPN, aplicaciones corporativas) se deshabilitan en un plazo máximo de 4 horas para bajas voluntarias y de forma inmediata para bajas disciplinarias.
3. El dispositivo corporativo es recuperado y sometido a borrado seguro.
4. Se verifica en el IAM que no queda ningún acceso activo del usuario en ningún sistema en el plazo de 24 horas.

ANEXO D – CONTACTOS DE SEGURIDAD Y CRISIS

Rol	Nombre	Email	Teléfono/Ext.
Responsable Servicio	Borja Rodríguez	res.servicio@athenea.es	Ext. 800
Responsable Seguridad	Miguel Zamora	res.seguridad@athenea.es	Ext. 801
SOC — Centro Operaciones Seguridad	Equipo SOC	soc@athenea.es	Ext. 900 (24x7 P1)
Delegado Protección de Datos (DPD)	Iván Morán	dpd@athenea.es	Ext. 802
CCN-CERT (incidentes ENS)	CERT Nacional CCN	cert@ccn-cert.cni.es	+34 91 395 49 01
AEPD (brechas datos personales)	Ag. Esp. Protección Datos	sgd@aepd.es	+34 91 266 35 17
Fiscalía de Menores (si afecta a menores)	Fiscalía General del Estado	fiscalia@fiscal.es	+34 91 335 26 00

